



# 資安職能訓練- 資通安全概論 (第3天)

數位發展部資通安全署 編製



# 第7單元

## 資通安全技術面應辦事項 - 安全性檢測及資通安全健診



## 第7單元學習目標

- 7-1 了解「安全性檢測」規定
- 7-2 了解「弱點掃描」規定
- 7-3 了解「滲透測試」規定
- 7-4 了解「應用程式安全」
- 7-5 了解「資通安全健診」規定
- 7-6 了解「網路安全」
- 7-7 了解「實體安全」



## 7-1 安全性檢測規定

- 安全性檢測包含核心資通系統之弱點掃描與滲透測試
- 不同資通安全責任等級之安全性檢測頻率如下

| 機關級別 | 弱點掃描  | 滲透測試  |
|------|-------|-------|
| A    | 每年2次  | 每年1次  |
| B    | 每年1次  | 每2年1次 |
| C    | 每2年1次 | 每2年1次 |
| D    | 無要求   | 無要求   |
| E    | 無要求   | 無要求   |



## 7-2 弱點掃描(1/15)

### ■ 何謂弱點掃描：

是一種資安評估方法，係透過特定的工具或程序，檢查系統或應用程式是否存在已知的安全弱點。

### ■ 目的：

- **評估資安防護能力：** 了解掃描目標目前的資安保護狀況。
- **發現潛在弱點：** 主動找出可能被利用的安全漏洞。
- **提供改善建議：** 依據掃描結果，提供修補弱點的方法與建議。
- **提升系統安全：** 協助組織根據掃描結果進行修補，強化整體系統的安全防護成效。
- **作為管理依據：** 掃描結果可作為主機資訊安全管理的參考基準。
- **確認弱點已排除：** 透過後續複掃，驗證已發現的弱點是否已成功修補。



## 7-2 弱點掃描(2/15)

### ■ 弱點掃描的類型：

根據掃描目標的性質，常見的弱點掃描通常分為以下主要類型：

#### ➤ 主機系統-弱點掃描：

- 針對作業系統、網路服務、系統設定、帳號密碼管理等進行掃描。
- 檢查項目例如 (至少應符合 Common Vulnerabilities and Exposures (CVE) 發布的弱點內容)：
  - 作業系統未修正的弱點。
  - 常用應用程式的弱點。
  - 網路服務程式的弱點。
  - 木馬、後門程式的掃描。
  - 帳號密碼破解測試。
  - 系統的不安全或錯誤設定。
  - 網路通訊埠掃描。



## 7-2 弱點掃描(3/15)

### ■ Web 網頁-弱點掃描：

- 針對網站應用程式的安全弱點進行掃描。
- 檢查項目(符合 OWASP TOP 10：2025等最新版本)：
  - A01 Broken Access Control ( 存取控制失效 )
  - A02 Security Misconfiguration ( 安全設定錯誤 )
  - A03 Software Supply Chain Failures ( 軟體供應鏈錯誤 )
  - A04 Cryptographic Failures ( 加密失效 )
  - A05 S Injection ( 注入式攻擊 )
  - A06 Insecure Design ( 不安全設計 )
  - A07 Authentication Failures ( 鑑別失效 )
  - A08 Software or Data Integrity Failures ( 軟體及資料完整性失效 )
  - A09 Security Logging and Alerting Failures ( 安全日誌及監控失效 )
  - A10 Mishandling of Exceptional Conditions ( 特殊情況處理不當 )



## 7-2 弱點掃描(4/15)

### ■ 弱點掃描流程







## 7-2 弱點掃描(5/15)



### ■ 如何執行弱點掃描？弱點掃描服務通常包含以下步驟：

- **事前準備與了解：**
  - － 與目標組織溝通，了解其網路架構、系統環境（設備廠牌、系統版本等）。
- **工具準備：**
  - － 使用取得合法授權的商業掃描軟體。
  - － 在每次掃描前，將掃描工具的弱點資料庫更新至最新版本，確保掃描的完整與正確。
- **執行初掃及產出報告：**
  - － 安排適當的掃描時間，通常在非公務時段或與組織協調進行，以減少對正常運作的影響。
  - － 執行「初掃」及產出初掃報告。
- **協助修補與追蹤：**
  - － 根據初掃結果，服務提供者協助組織理解發現的弱點並提供修補建議。
  - － 追蹤弱點修補進度，記錄未修補或排除的原因。
- **執行複掃及產出報告：**
  - － 在弱點修補後，就原先初掃報告找出之弱點，再次執行「複掃」及產出複掃報告。
  - － 目的是確認先前的弱點是否已成功排除，確保掃描目標的安全。
  - － 若複掃仍發現未修補的弱點，服務提供者應協助組織解決問題。



## 7-2 弱點掃描(6/15)

### ■ 弱點掃描的報告：

弱點掃描的主要產出是詳細的掃描報告，通常包含以下內容

- **執行結果摘要：** 簡要說明掃描結果。
- **專案執行計畫：** 說明掃描期間、項目、範圍、執行人員、使用工具及方法。
- **弱點統計分析：** 依風險等級 (如：高、中、低) 及弱點類別進行分類統計
- **詳細弱點清單：**
  - 列出每個發現的弱點名稱、描述、受影響的設備名稱、IP/URL、服務埠 (Port)。
  - 標示弱點的風險等級。
  - 提供具體的修補建議。
- **掃描誤判清單：** 說明被掃描工具標示為弱點但經人工判斷為誤判的項目及理由。
- **弱點排除清單：** 說明因特定原因 (如：無法修補、已有其他配套措施) 而暫不修補的弱點及其理由。
- **複掃報告的差異化分析：** 複掃報告應提供與初掃結果的比較，例如列出未修補的弱點或新發現的弱點等。



## 7-2 弱點掃描(7/15)

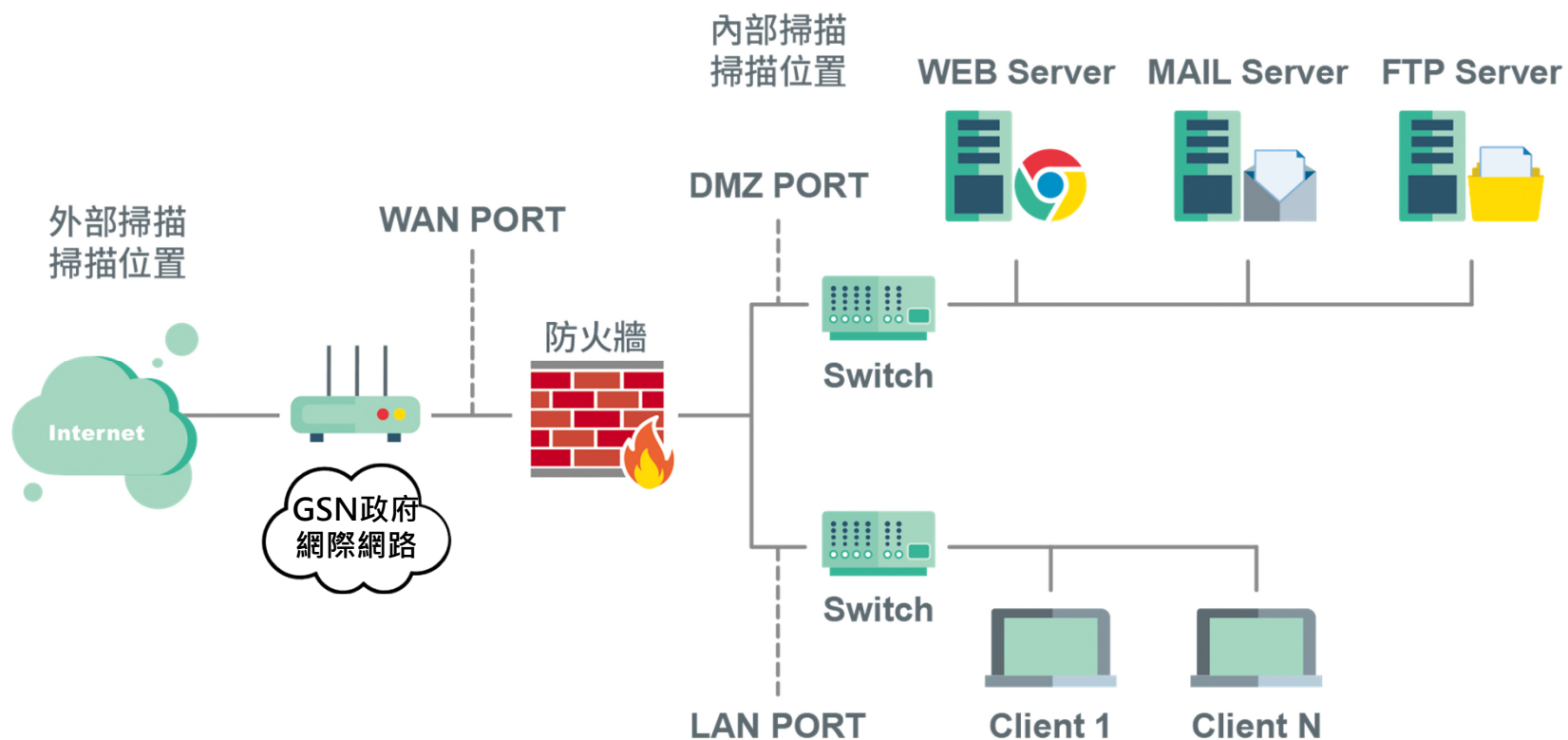
### ■ 弱點掃描考慮因素

- 內部掃描 VS 外部掃描
- 有登錄權限(Authenticated) VS 無登錄權限(Unauthenticated)
- 侵入式 VS 非侵入式
- 委外VS 機關IT資安部門



## 7-2 弱點掃描(8/15)

### ■ 內部掃描 VS 外部掃描





## 7-2 弱點掃描(9/15)

### ■ 有登錄權限 VS 無登錄權限

- 使用“有登錄權限”進行弱點掃描可以較“無登錄權限”更為深入與澈底
  - 無登錄權限僅能測試到登錄的功能而已
  - 有登錄權限可以測到登錄後更多的功能



## 7-2 弱點掃描(10/15)

### ■ 侵入式 VS 非侵入式

#### ➤ 非侵入式：

- 不會對目標系統造成影響，主要透過分析響應判斷弱點。
- 安全性高，適合運作中環境

#### ➤ 侵入式：

- 可能對系統造成不穩定或破壞，通常用於滲透測試，需謹慎授權。
- 弱點掃描主要採用非侵入式。



## 7-2 弱點掃描(11/15)

### ■ 委外VS 機關資安部門自行執行

#### ➤ 委外

- 委外通常須簽訂契約，按照契約進行較無彈性，須事先考慮清楚
- 弱點掃描費用通常與主機數量、掃描次數正相關

#### ➤ 機關資安部門自行執行弱點掃描需考量因素

- 弱點掃描軟體的購置與持續更新
- 弱點掃描之專業人才



## 7-2 弱點掃描(12/15)

### ■ 弱點掃描服務委外(1/4)

➤ 參考「政府機關弱點掃描服務委外服務案建議書徵求文件」摘錄部分重要內容，包含：

#### 壹、專案概述

- 一、專案名稱
- 二、專案目標
- 三、專案範圍
- 四、專案期間

#### 貳、專案工作項目

掃描內容

#### 參、管理需求

- 一、廠商資格
- 二、服務水準協定(SLA)與罰責
- 三、品質需求與驗收標準
- 四、業務保密安全責
- 五、專案經費預算金額

#### 肆、交付項目

- 一、交付項目與時程
- 二、交付文件格式
- 三、交付項目說明

#### 伍、建議書製作規定

- 一、服務建議書格式
- 二、服務建議書內容





## 7-2 弱點掃描(13/15)

### ■ 弱點掃描服務委外(2/4)

#### ➤ 壹、專案概述

針對整個專案整體性的描述

##### 壹、專案概述

###### 一、專案名稱

「弱點掃描服務」委外服務案（以下簡稱本案）。

###### 二、專案目標

藉由本案之執行成果，以掃描目標之資安防護能力與發現潛在弱點，並依據掃描結果提出改善建議，協助掃描目標提升系統安全防護成效。

###### 三、專案範圍

本案的服務範圍設備清單詳見附件 1。

###### 四、專案期間

自簽約日起至 XXX 年 XX 月 XX 日止。

附件1 弱點掃描服務範圍設備清單

例如：

| 項目 | 掃描類別   | IP / URL | 設備種類(如主機/伺服器種類、通訊設備種類、個人電腦等) | 備註 (如設備廠牌、系統版本) |
|----|--------|----------|------------------------------|-----------------|
| 1  | 系統弱點掃描 |          |                              |                 |
| 2  | 網站弱點掃描 |          |                              |                 |
|    |        |          |                              |                 |



## 7-2 弱點掃描(14/15)

### ■ 弱點掃描服務委外(3/4)

#### 貳、專案工作項目

- 針對機關主機系統與Web 網頁進行安全弱點掃描，評估掃描標的物是否存在安全弱點，同時提供相關掃描結果，做為主機資訊安全的管理依據，並協助弱點修補方法之參考建議，待修正弱點後提供複掃，以確認弱點已經排除

#### OWASP TOP10 2025

| 主機系統弱點掃描                                                                                                  | Web 網頁弱點掃描                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|-----------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1.作業系統未修正的弱點掃描<br>2.常用應用程式弱點掃描<br>3.網路服務程式掃描<br>4.木馬、後門程式掃描<br>5.帳號密碼破解測試<br>6.系統之不安全與錯誤設定掃描<br>7.網路通訊埠掃描 | 1. A01 Broken Access Control ( 存取控制失效 )<br>2. A02 Security Misconfiguration ( 安全設定錯誤 )<br>3. A03 Software Supply Chain Failures ( 軟體供應鏈錯誤 )<br>4. A04 Cryptographic Failures ( 加密失效 )<br>5. A05 S Injection ( 注入式攻擊 )<br>6. A06 Insecure Design ( 不安全設計 )<br>7. A07 Authentication Failures ( 鑑別失效 )<br>8. A08 Software or Data Integrity Failures ( 軟體及資料完整性失效 )<br>9. A09 Security Logging and Alerting Failures ( 安全日誌及監控失效 )<br>10. A10 Mishandling of Exceptional Conditions ( 特殊情況處理不當 ) |



## 7-2 弱點掃描(15/15)

### ■ 弱點掃描服務委外(4/4)

#### 參、管理需求

- 一、廠商資格
- 二、服務水準協定(SLA)與罰責
- 三、品質需求與驗收標準
- 四、業務保密安全責任

#### 肆、交付項目

- 一. 工作計畫書
- 二. 弱點掃描服務中文報告
- 三. 弱點複掃服務中文報告

詳細服務水準規範如下表：

| 項次 | 項目         | 服務水準                                                       |
|----|------------|------------------------------------------------------------|
| 1  | ▪ 執行時程     | ▪ 初掃：每次以 2 週為限<br>▪ 複掃：每次以 2 週為限<br>▪ 掃描報告：初掃及複掃結束後 2 週內提供 |
| 項次 | 項目         | 服務水準                                                       |
| 2  | ▪ 設備服務中斷時間 | ▪ 因執行弱點掃描服務造成軟硬體設備服務中斷時，應協助機關恢復正常運作，服務中斷時間不得超過 8 小時        |



## 7-3 滲透測試(1/5)

### ■ 何謂滲透測試：

是一種資安評估方法，係透過模擬有心人士之攻擊方式，對系統或物聯網設備進行安全強度的測試。

### ■ 目的：

- **評估防護能力**：檢測受測目標在遭遇攻擊活動時之資安防護能力與執行成效。
- **發現潛在弱點**：主動找出可能被利用的安全漏洞。
- **提供改善建議**：依據掃描結果，提供修補弱點的方法與建議。
- **確認弱點已排除**：透過複測，確認初測找出之資安漏洞已經完成修正。
- **精進整體防護**：透過滲透測試報告及改善建議，檢討與精進受測目標之整體資安防護作為。



## 7-3 滲透測試(2/5)

■ **滲透測試的類型**：滲透測試的範圍廣泛，主要針對作業系統、應用程式、服務及物聯網設備：

➤ **測試類型及測試項目**：測試項目考參國家資通安全研究院之資安服務需求建議書範本

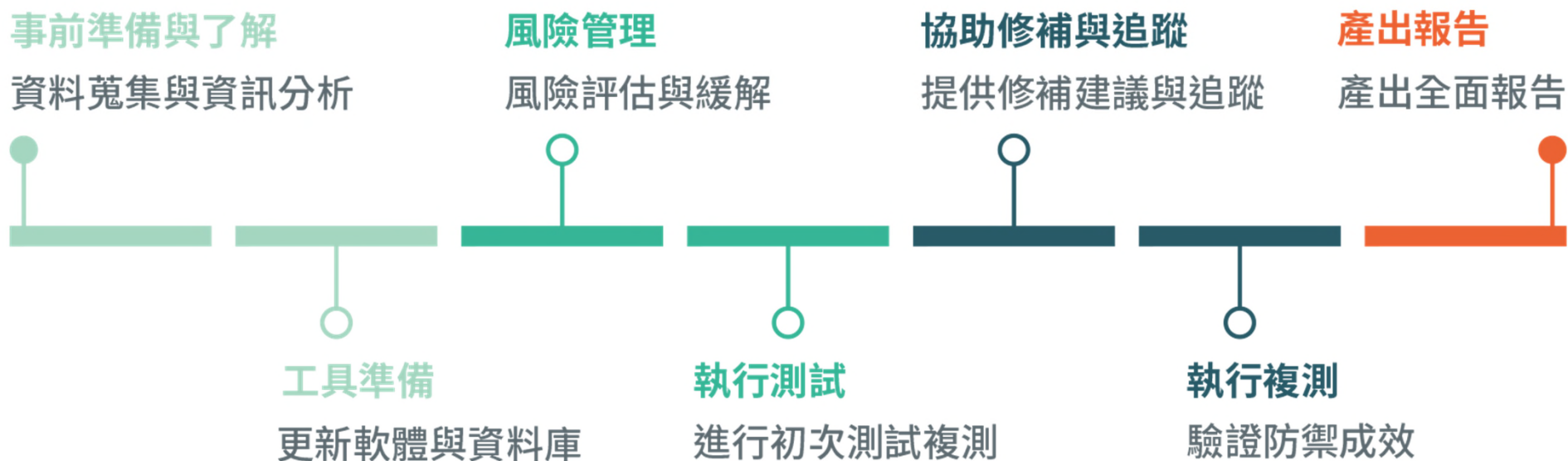
| 測試類別 | 測試項目        |
|------|-------------|
| 作業系統 | 遠端服務        |
|      | 本機服務        |
| 網站服務 | 設定管理        |
|      | 使用者認證       |
|      | 連線管理        |
|      | 使用者授權       |
|      | 邏輯漏洞        |
|      | 輸入驗證        |
|      | Web Service |
|      | Ajax        |

| 測試類別 | 測試項目     |
|------|----------|
| 應用程式 | 電子郵件服務套件 |
|      | 檔案傳檔服務套件 |
|      | 遠端連線服務套件 |
|      | 網路服務套件   |
|      | 其它       |
| 密碼破解 | 密碼強度測試   |
| 無線服務 | 無線服務弱點測試 |



## 7-3 滲透測試(3/5)

### ■ 滲透測試流程







## 7-3 滲透測試(4/5)

### ■ 滲透測試如何進行？滲透測試服務通常包含以下步驟：

- **事前準備與了解：**
  - 對受測目標進行資料蒐集與資訊分析，作為執行測試的決策依據。
- **工具準備：**
  - 使用取得合法授權的商業滲透測試軟體。
  - 在每次掃描前，將掃描工具的弱點資料庫更新至最新版本，確保掃描的完整與正確。
- **風險管理：**執行具侵入性質的檢測作業前，需與組織進行確認，並具備適當應變措施與風險評估後才進行。事前需提出對受測目標進行備份建議。
- **執行測試(模擬攻擊)：**
  - 可針對**網際網路**及/或**內部網路**進行測試。網際網路測試通常由遠端進行，內部網路測試則於現場進行。
  - **安排適當的執行時間**，通常於非公務時段或與組織協調適當時間進行。
  - 通常包含初次測試(初測)，包括探索、弱點發掘、漏洞利用
- **協助修補與追蹤：**
  - 初測後，應協助組織理解發現的弱點，提供修補建議，並對應修補之弱點進行追蹤管理
- **執行複測(驗證防禦成效)：**
  - 在弱點修補後，再次執行複測。
  - 目的是確認先前的弱點是否已成功排除，確保掃描目標的安全。
  - 若複測仍發現未修補的弱點，服務提供者應協助組織解決問題。
- **產出報告：**產出詳細的滲透測試報告



## 7-3 滲透測試(5/5)

■ **滲透測試的報告**：滲透測試的核心成果是詳細的測試報告(初測及複測)，通常包含以下內容：

- **執行結果摘要**：包括受測目標風險等級與數量列表/受測目標風險漏洞名稱列表/風險漏洞分布列表，以及簡要說明滲透測試結果。
- **專案執行計畫**：包括測試期間、執行項目、執行範圍、執行人員及使用工具
- **滲透測試弱點發現**：
  - 列出詳細的測試結果
  - 應說明**詳細過程及內容**（包括檢測目標、弱點名稱、問題 URL/IP、問題參數、測試語法、測試截圖等）
  - 說明**可能造成的風險**
- **分析報告**：對測試結果進行統計分析。。
- **改善與建議**：著重於提供**弱點修補建議**，以利組織快速掌握弱點並進行修復。
- **結論**。





## 7-4 應用程式安全(1/15)

### ■ 應用程式安全

- **軟體安全工程探討軟體安全問題的解決方法**
  - 應用安全屬於軟體工程的問題，由設計來解決
  - 架構安全屬於系統管理問題，由設定來解決
- **安全要求高的軟體，需要特別訂定安全性規格**
  - 從實際應用的角度來評估風險
  - 依實際的需求來設計軟體系統降低風險與損害



## 7-4 應用程式安全(2/15)

### ■ 系統開發思維

#### ➤ 傳統系統開發之特性

- 功能性導向，在最短的時間，完成系統的開發與上線
- 缺乏安全性考量的設計，面對日新月異的攻擊手法，難以建立有效的防護方法保護系統的安全，例如:資料隱碼攻擊(SQL Injection)等便是因此而崛起

#### ➤ 安全系統開發生命週期 (SSDLC)之思維

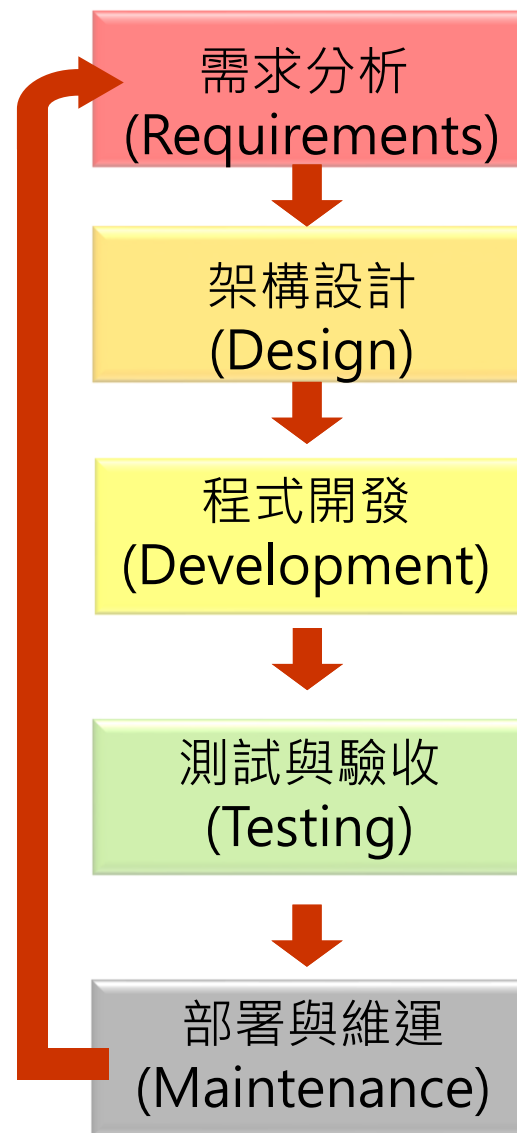
- 在考量系統功能性的同時，導入安全性的思維，於系統開發過程中均進行各項必要的安全控制措施，雖開發時程長，卻降低了系統後續維運的成本與遭受入侵的損失



## 7-4 應用程式安全(3/15)

### ■ 安全系統開發生命週期 (1/3)

- 安全系統開發生命週期  
(Secure Systems Development Life Cycle, SSDLC)意指發展一套安全軟體之順序，主要可分為以下步驟：





## 7-4 應用程式安全(4/15)

### ■ 安全系統開發生命週期 (2/3)

#### ➤ 需求分析 (Requirements)

- 進行風險分析與確認應用程式的資安需求，以符合使用者需求與法規遵循為目的

#### ➤ 架構設計 (Design)

- 根據需求分析結果，進行包含系統任務的目標、功能關聯、邊界範圍及各階層使用者的角色等內外部使用的規劃與搭配適當的資安架構

#### ➤ 程式開發 (Development)

- 落實既有之規劃，將使用者介面、功能運作及安全性等完整的實現
- 程式設計師應隨時注意正確安全的程式撰寫習慣



## 7-4 應用程式安全(5/15)

### ■ 安全系統開發生命週期 (3/3)

#### ➤ 測試與驗收 (Testing)

- 依據資安需求擬訂測試計畫，並依測試計畫進行測試與修正
- 確保各項功能與安全性皆可符合既定的需求

#### ➤ 部署與維運 (Maintenance)

- 進行軟體之部署，安排教育訓練
- 落實軟體之穩定運作，應定期修補漏洞(Patch)、按步升級更新版本(Upgrade)及即時監控(Monitor)



## 7-4 應用程式安全(6/15)

### ■ 安全控制-變更控制(1/2)

#### ➤ 原因

- 應用程式上線後因需求的變更、新功能要求及發現瑕疵等因素，需要變更應用系統程式或組態

#### ➤ 目的

- 為維持變更後的安全狀態仍可符合安全政策要求

#### ➤ 方法

- 機關應實作應用程式變更控制流程
- 必須確保變更是獲得授權、經過測試且被記錄下來



## 7-4 應用程式安全(7/15)

### ■ 安全控制-變更控制(2/2)

#### ➤ 變更控制之步驟

- 變更需求管理:
  - ✓ 填寫變更需求申請
  - ✓ 分析變更需求
  - ✓ 發展實作策略、方法或步驟
  - ✓ 計算變更所需成本
- 變更評估:
  - ✓ 評估變更與安全的關聯性
  - ✓ 記錄變更請求
- 變更審查
  - ✓ 提交變更申請進行核准
  - ✓ 變更開發
  - ✓ 進行應用程式變更的開發工作
  - ✓ 記錄變更開發的產出(新增或刪除功能)
- 變更測試與部署
  - ✓ 將變更的程式碼與變更申請連結(程式碼中的註解)
  - ✓ 將變更後的程式碼交付測試與品質認可
  - ✓ 變更程式碼版本(上線)
- 變更結果報告
  - ✓ 向管理階層報告變更結果





## 7-4 應用程式安全(8/15)

### ■ 安全控制-職責區隔

- 作業人員不應有權限存取線上的程式碼或程式物件
- 程式設計人員不應存取線上運作中的軟體
- 品管部門應測試程式碼品質，且與開發部門採用不同的測試方法
- 一旦軟體被開發測試完成應被保存在程式庫中
- 線上運作的軟體應由程式庫中發行，不應直接由程式設計人員或測試人員進行更新





## 7-4 應用程式安全(9/15)

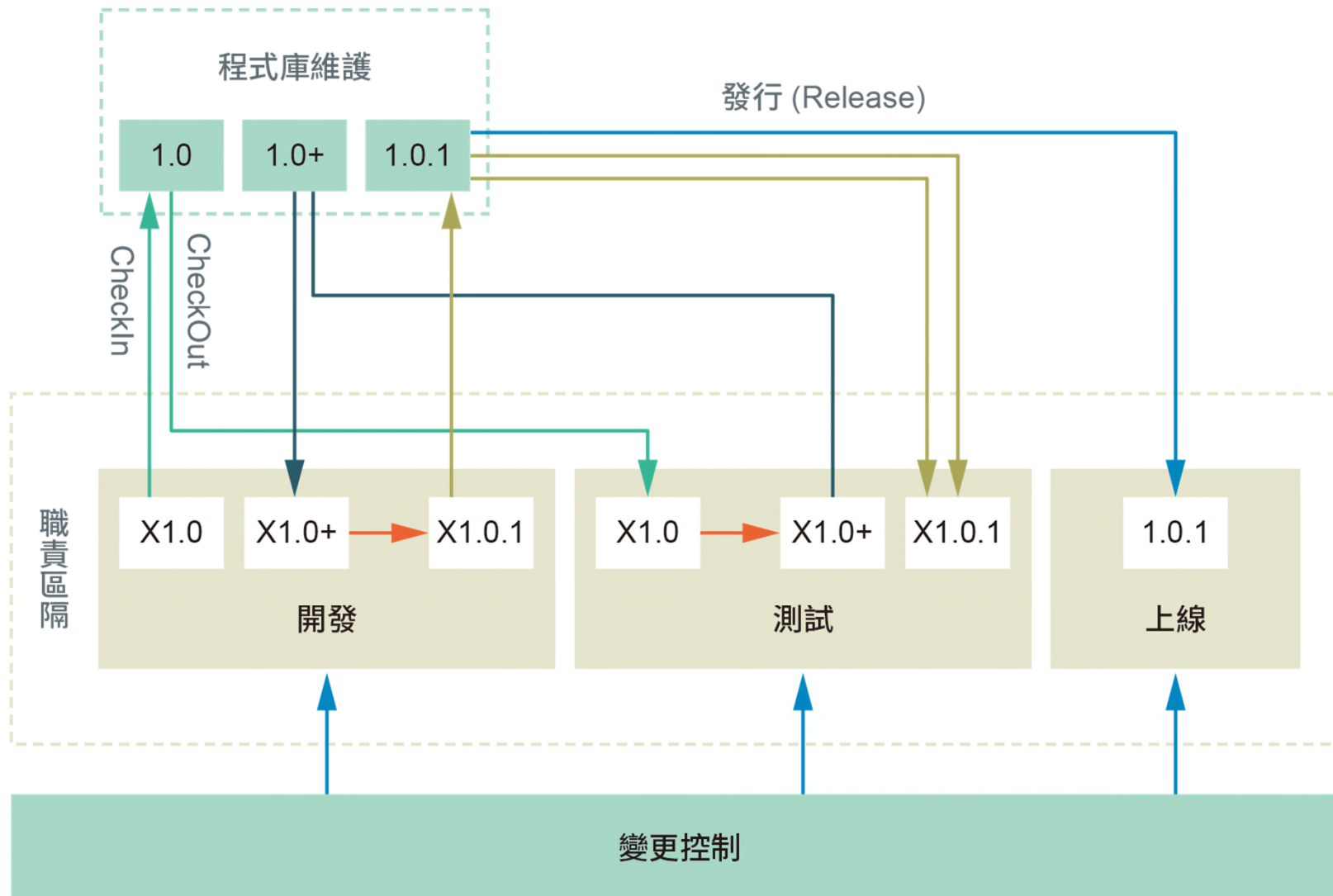
### ■ 安全控制-程式庫維護(1/2)

- 應用程式應集中存放在程式庫中，並進行存取控管
- 程式庫進行版本控制，並保留所有版本程式碼
  - 主版本：1.0
  - 次版本：1.1
  - 緊急修正版本：1.0.1
- 開發部門凍結版本後，應簽入(Check In)到程式庫，也應由程式庫中簽出(Check Out)取得最新版本進行修改
- 測試部門應由程式庫中簽出(Check Out)取得最新版本進行測試
- 上線人員應由程式庫中發行(Release)最新版本應用程式至線上系統



## 7-4 應用程式安全(10/15)

### ■ 安全控制-程式庫維護(2/2)





## 7-4 應用程式安全(11/15)

### ■ 行動應用程式安全

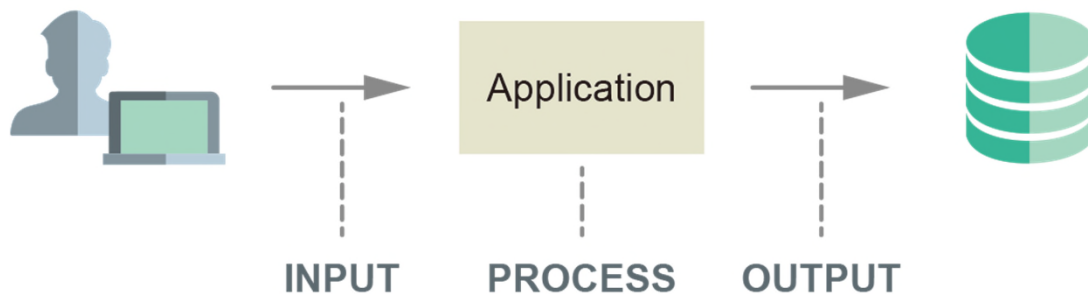
- 行動應用程式(App)也是應用程式的一環
- 駭客可循傳統的技術進行病毒的感染
- 駭客可運用反向工程的技術來變造原來的程式，將變造後的App上傳到程式商店引誘使用者下載
- 開發App時，需注意採用套件的安全
- 開發App時，索取過多行動裝置上的敏感資訊，例如：通訊錄、行事曆、座標位置、郵件、簡訊內容等，易侵犯隱私
- 不要在手機裡儲存重要資料，也不要下載不明APP，保護自己個資與財務安全



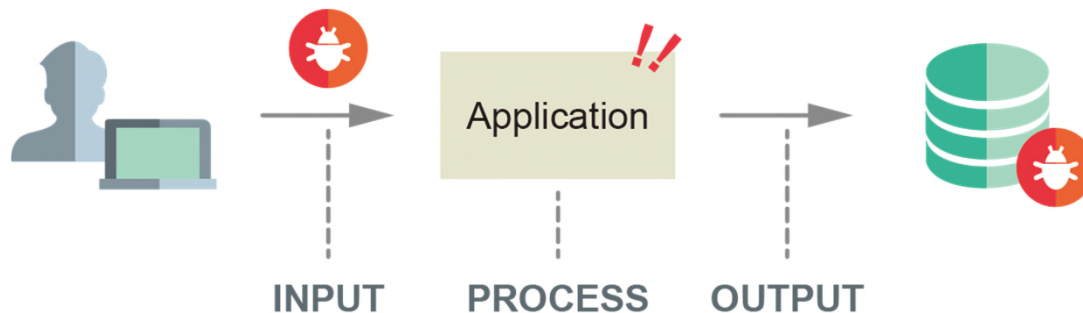
## 7-4 應用程式安全(12/15)

### ■ 安全威脅-輸入攻擊(1/2)

- 應用程式從使用者端取得輸入資料，進行資料運算與處理，最後將運算處理結果輸出



- 如果使用者輸入惡意資料，應用程式沒有檢查過濾，便可能造成程式發生錯誤、執行邏輯被改變及存取權限跳脫等問題





## 7-4應用程式安全(13/15)

### ■ 安全威脅-輸入攻擊(2/2)

- Web應用程式常見的攻擊大都屬於輸入攻擊
  - SQL Injection
  - Cross-Site Scripting
- 應用程式於收到「不可信任來源」所輸入的資料時，應先進行過濾與正規化(長度或形態)後，才進行後續作業



## 7-4 應用程式安全(14/15)

### ■ WEB應用程式-檢測(1/2)

- 定期針對核心資通系統執行弱點掃描(A級機關每年2次，B級機關每年1次)與滲透測試(A級機關每年1次，B級機關每2年1次)
  - 黑箱檢測工具(模擬SQL Injection、XSS等攻擊)
  - 白箱檢測工具(靜態分析應用程式原始碼)
  - 滲透測試(權限跳脫與邏輯錯誤)
- 如有能力修改程式
  - 修補已發現的應用程式弱點
- 如無能力修改程式
  - 建置Web應用程式防火牆進行弱點防禦



## 7-4 應用程式安全(15/15)

### ■ WEB應用程式-檢測(2/2)

| 檢測方式           | 黑箱檢測法  |          | 白箱檢測法  |        |
|----------------|--------|----------|--------|--------|
|                | 人工滲透測試 | AP弱點掃描工具 | 人工源碼掃描 | 自動源碼掃描 |
| 弱點定位精準         | 普      | 差        | 佳      | 優      |
| 檢測詳細程度         | 差      | 普        | 佳      | 優      |
| 執行時錯誤          | 優      | 佳        | 差      | 差      |
| 邏輯性錯誤          | 佳      | 普        | 差      | 差      |
| 存取控管機制         | 佳      | 普        | 差      | 差      |
| 檢測時效           | 差      | 佳        | 差      | 優      |
| 程式開發人員<br>修補溝通 | 普      | 差        | 佳      | 優      |
| 誤判情形           | 優      | 普        | 佳      | 普      |
| 綜合評比           | 佳      | 普        | 普      | 優      |

建議：預算充足可同時採用「自動源碼掃描」與「人工滲透測試」，若預算有限則優先採用「自動源碼掃描」



## 7-5 資通安全健診(1/10)

### ■ 健診目的

- 整合各資通安全項目的檢視服務作業，提供機關資通安全改善建議
- 藉由實施技術面與管理面的相關控制措施，提升機關整體資通安全防護能力
- 針對已知弱點進行修補，並持續追蹤可能存在的風險

### ■ 辦理健診的頻率

| 辦理項目       | 辦理項目細項             | 機關         |             |       |
|------------|--------------------|------------|-------------|-------|
|            |                    | A級         | B級/C級       | D級/E級 |
| 資通安全<br>健診 | 網路架構檢視             | 每年<br>辦理1次 | 每2年<br>辦理1次 | 無要求   |
|            | 網路惡意活動檢視           |            |             |       |
|            | 使用者端電腦惡意活動檢視       |            |             |       |
|            | 伺服器主機惡意活動檢視        |            |             |       |
|            | 目錄服務系統設定及防火牆連線設定檢視 |            |             |       |
|            | 核心資通系統資料庫安全檢視      |            |             |       |





## 7-5 資通安全健診(2/10)

### ■ 健診項目(1/4)

#### ➤ 網路架構檢視

- 針對網路架構圖進行安全性弱點檢視，詳列發現事項之風險等級、風險說明與改善建議，以利機關後續修補與調整

#### ➤ 網路惡意活動檢視

- 架設封包側錄設備，觀察內部電腦或設備是否有對外之異常連線，發現異常連線之電腦或設備應確認使用狀況與用途
- 檢視資安設備紀錄檔，分析過濾內部電腦或設備是否有對外之異常連線紀錄，發現異常連線之電腦或設備應確認使用狀況與用途



## 7-5 資通安全健診(3/10)

### ■ 健診項目(2/4)

#### ➤ 使用者端電腦惡意活動檢視

- 檢視使用者電腦之作業系統更新情形
- 檢視使用者電腦之應用程式之安全性更新情形
- 檢視使用者電腦是否使用已經停止支援之作業系統或軟體
- 檢視使用者電腦防毒軟體安裝、更新及定期掃描結果之處理情形



## 7-5 資通安全健診(4/10)

### ■ 健診項目(3/4)

#### ➤ 伺服器主機惡意活動檢視

- 檢視伺服器主機之作業系統更新情形
- 檢視伺服器主機應用程式之安全性更新情形
- 檢視伺服器主機是否使用已經停止支援之作業系統或軟體
- 檢視伺服器主機是否使用不合宜之作業系統
- 檢視伺服器主機防毒軟體安裝、更新及定期掃描結果之處理情形



## 7-5 資通安全健診(5/10)

### ■ 健診項目(4/4)

#### ➤ 目錄服務系統設定及防火牆連線設定檢視

- 目錄服務系統組態設定，以行政院國家資通安全研究院所發展之「政府組態基準」內容為標準，確認目錄服務系統組態設定落實情形
- 檢視防火牆連線設定規則是否有安全性弱點，確認來源與目的 IP 及通訊埠連通之適切性

#### ➤ 核心資通系統資料庫安全檢視

- 檢視資料庫之特權帳號管理及資料加密
- 檢視資料庫之存取授權及稽核紀錄
- 檢視資料庫之委外管理
- 檢視資料庫之備份保護
- 檢視資料庫之弱點管理



## 7-5 資通安全健診(6/10)

### ■ 健診流程(1/5)

#### ➤ 基本環境調查

- 使用者電腦與伺服器主機資訊
- 政府組態基準部署現況與例外管理清單
- 服務主機與防護設備資訊
- 網段劃分資訊
- 網路交換器(Switch)是否支援Port Mirror功能
- 是否有網域環境

#### ➤ 決定範圍與抽樣方式

- 範圍與抽樣方式須具有代表性
- 以範圍與抽樣方式決定檢測時程與預算金額



## 7-5 資通安全健診(7/10)

### ■ 健診流程(2/5)

#### ➤ 檢測配合事項(由受測單位提供資料給檢測單位)

- 檢測環境
- 網路架構檢視
- 網路惡意活動檢視
- 使用者端電腦惡意活動檢視
- 伺服器主機惡意活動檢視
- 目錄服務系統設定檢視
- 防火牆連線設定檢視
- 核心資通系統資料庫安全檢視



## 7-5 資通安全健診(8/10)

### ■ 健診流程(3/5)

#### ➤ 啟始會議

- 執行檢測前，須辦理啟始會議，說明檢測項目與範圍，協調配合事項並達成雙方共識
- 參與人員應包含機關主管與相關業務承辦人

#### ➤ 執行檢測(根據啟始會議決議項目執行)

- 網路架構檢視
- 網路惡意活動檢視
- 使用者端電腦惡意活動檢視
- 伺服器主機惡意活動檢視
- 目錄服務系統設定及防火牆連線設定檢視
- 核心資通系統資料庫安全檢視



## 7-5 資通安全健診(9/10)

### ■ 健診流程(4/5)

#### ➤ 撰寫檢測報告

- 執行結果摘要
- 執行計畫
- 執行情形
- 結果建議
- 結論
- 附件

#### ➤ 提出改善建議

- 針對各檢測項目發現事項，須詳查根因並提出相對應之改善建議

### ■ 資通安全健診服務委外：請參考「政府機關資安健診服務委外服務案建議書徵求文件(範本)」





## 7-5 資通安全健診(10/10)

### ■ 健診流程(5/5)

#### ➤ 結束會議

- 檢測完成後，須辦理結束會議，說明各項目發現事項、改善建議與結論
- 參與人員應包含機關管理階層與相關業務承辦人

#### ➤ 修補規劃與追蹤

- 依據資安健診報告中之改善建議，規劃修補方式
  - ✓ 優先處理可即時修補與風險等級較高的弱點
  - ✓ 無法即時修補之弱點，需規劃改善計畫與改善時程，並持續追蹤修補進度
- 針對已修補弱點，須留存弱點修補紀錄
- 弱點修補完成後須執行複測，以確認修補方法之有效性



## 7-6 網路安全(1/21)

### ■ 網路區域規劃目的

- 為了清楚界定規劃不同屬性的區域
- 作為存取控制與安全規劃的基準群組
- 避免來自內部與外部的攻擊
- 防範災害擴大

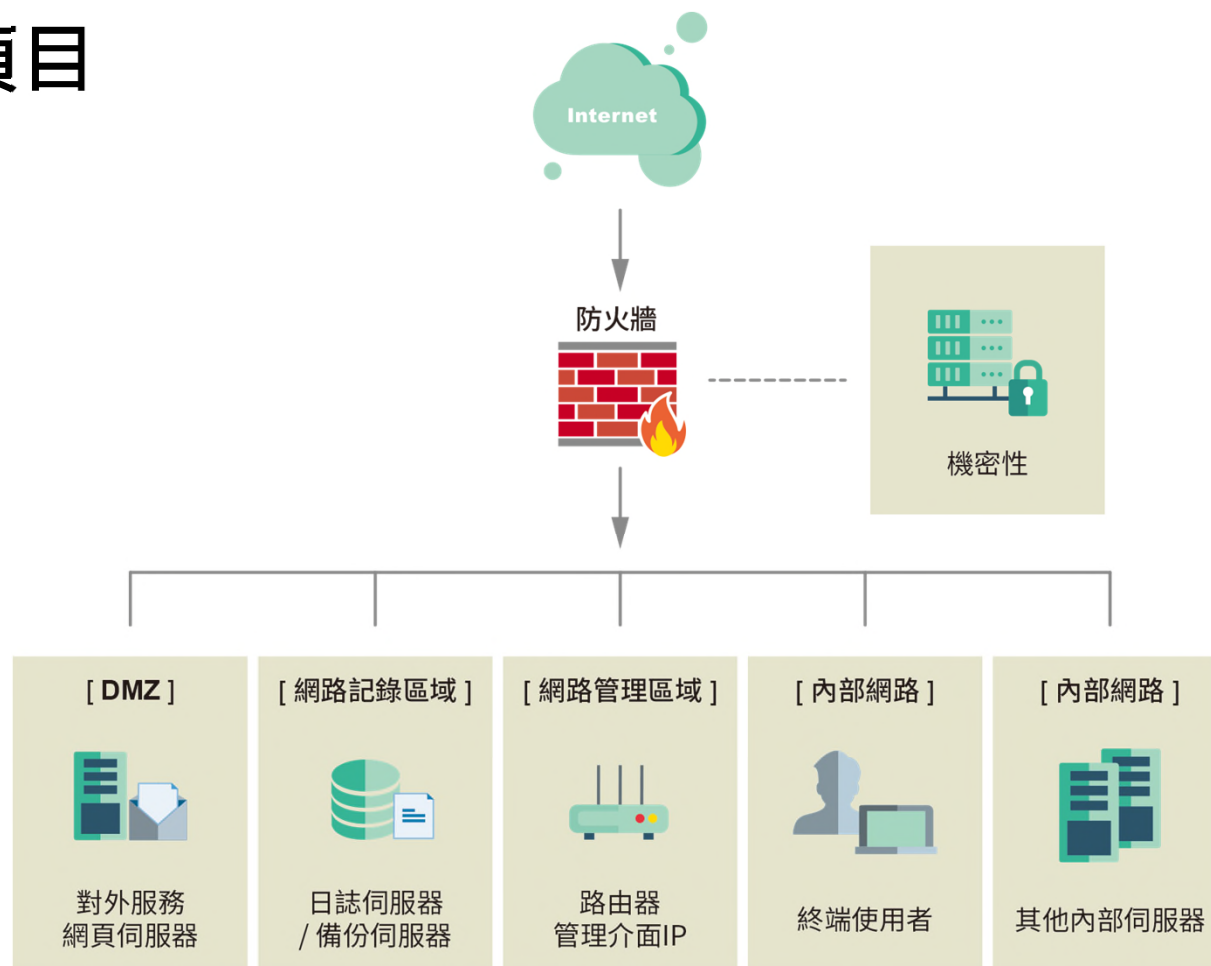


## 7-6 網路安全(2/21)

### ■ 網路區域規劃(1/6)

#### ➤ 建議區域劃分項目

- 外部網路
- 內部網路
- 非軍事區
- 網路管理區域
- 網路記錄區域
- 實體隔離區域



\*內部網路應視實際需求,評估是否再進行安全區域的細部隔離



## 7-6 網路安全(3/21)

### ■ 網路區域規劃(2/6)

#### ➤ 外部網路

- 機關對外網路區域，連接外部廣域網路(WAN)
- 此區域對內部需要經過防火牆的存取控制
- 非允許的服務與來源不能進入其他區域

#### ➤ 內部網路(LAN)

- 內部網路通常包含機關使用者終端、資通系統等設備
- 利用 VLAN與不同路由等方式切開
- 外部網路無法直接連線內部網路
- 可考慮於內部網路架設代理伺服器控管與外部網段之連線



## 7-6 網路安全(4/21)

### ■ 網路區域規劃(3/6)

#### ➤ 非軍事區(DMZ)

- DMZ主要是放置機關對外服務伺服器
  - 網頁伺服器
  - FTP伺服器
- 僅開放特定服務 (特定TCP Port)
- 需要嚴密控管此區域到內部區域的存取



## 7-6 網路安全(5/21)

### ■ 網路區域規劃(4/6)

#### ➤ 網路管理區域

- 放置機關網路管理設備
  - 網路管理系統
  - 認證系統
  - 監控系統
- 應明確標示網路的路徑及維運方式
- 網路設備維運應該與服務的網段有所區隔
- 避免當服務網段被攻擊，進而影響網路設備的管理



## 7-6 網路安全(6/21)

### ■ 網路區域規劃(5/6)

#### ➤ 網路紀錄區域

- 放置
  - 備份主機(Backup Server)
  - 紀錄主機(Log Server)
- 存放的網段應特別規劃
- 僅允許設備備份與紀錄之發送及管理員管理連線行為



## 7-6 網路安全(7/21)

### ■ 網路區域規劃(6/6)

#### ➤ 實體隔離區域

- 機關依據特定需求可將部分區域執行實體隔離
- 單向傳輸：僅可將資料傳出，不可傳入
- 可能危害途徑
  - 破解門禁系統
  - 利用隨身碟竊取資料
  - 私接網路對機密主機連線





## 7-6 網路安全(8/21)

### ■ 網路連線安全(1/3)

#### ➤ 傳輸加密

- 保護資料在傳輸過程中的機密性
- 採用通道加密與傳輸層加密 (如HTTPS)

#### ➤ 資訊機密性

- 利用對稱式與非對稱式加密演算法來達成

#### ➤ 資訊完整性

- 以數位簽章技術來達成



## 7-6 網路安全(9/21)

### ■ 網路連線安全(2/3)

#### ➤ HTTP、FTP與TELNET

- 連線採用明文傳輸，通訊內容有可能被監聽

#### ➤ HTTPS、FTPS與SSH

- 是一種加密的網路傳輸協定，可在不安全的網路中為網路服務提供安全的傳輸環境
- 可防止遭到竊聽與篡改訊息
- HTTPS連線時，可再檢查憑證是否有效



## 7-6 網路安全(10/21)

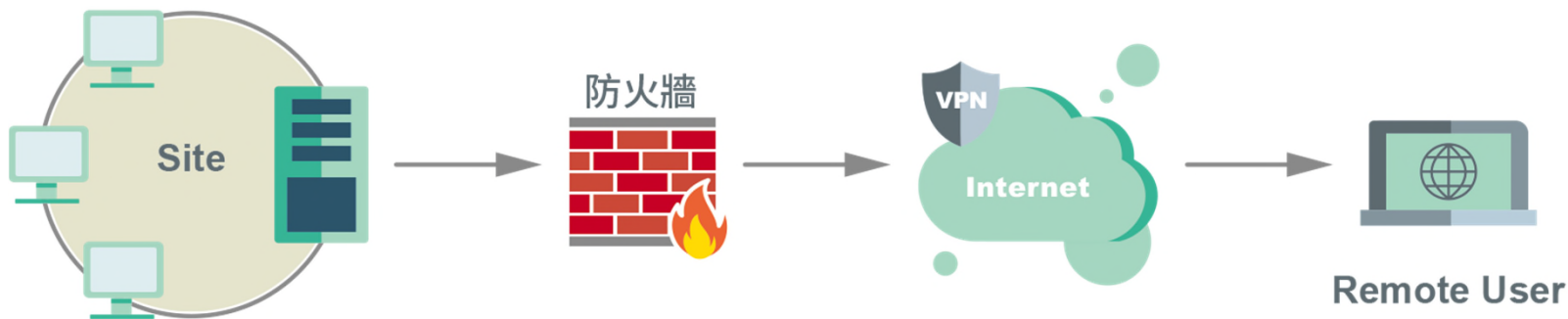
### ■ 虛擬私有網路(1/3)

#### ➤ 用途

- 在公開的網路上建立虛擬的私有通道
- 保護通訊資料的機密性與完整性

#### ➤ VPN類型

- 遠端使用者存取VPN：外勤人員透過網際網路與內部網路建立安全通道

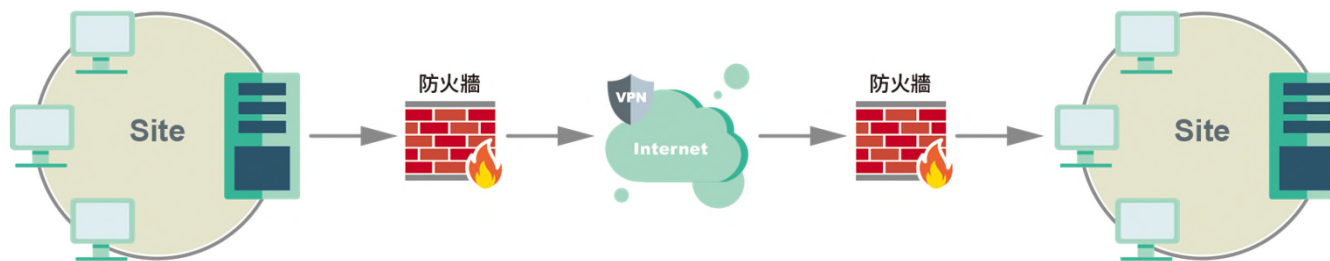




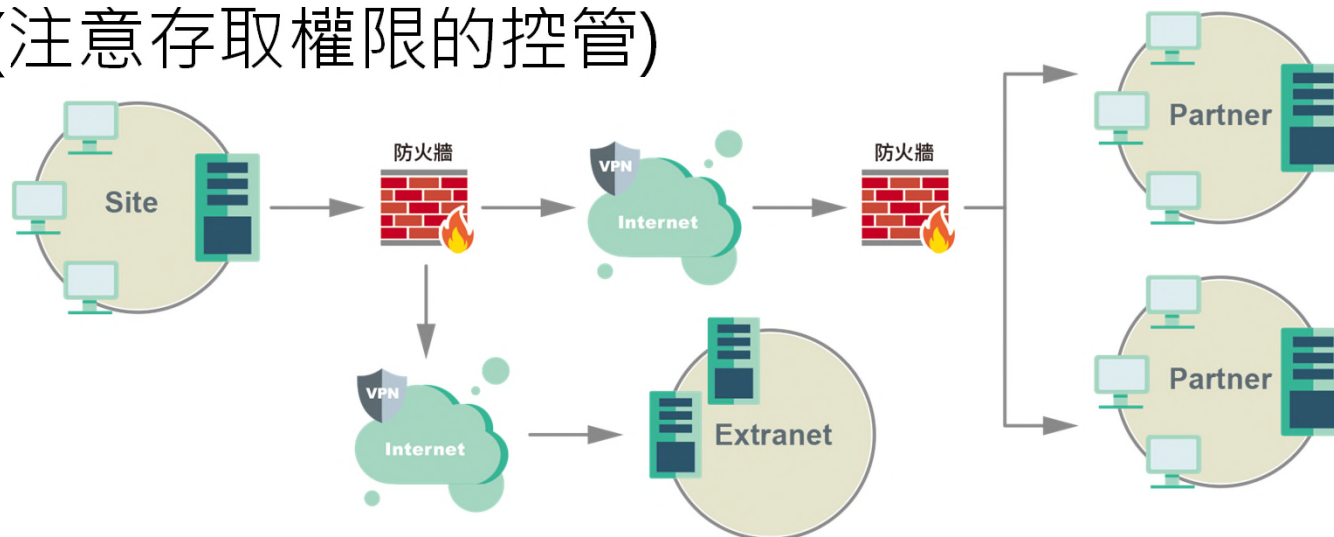
## 7-6 網路安全(11/21)

### ■ 虛擬私有網路(2/3)

- Site-to-Site VPN：總部與分點之內部網路透過網際網路建立安全通道



- Extranet VPN：與合作夥伴間透過網際網路建立安全通道(注意存取權限的控管)





## 7-6 網路安全(12/21)

### ■ 虛擬私有網路(3/3)

#### ➤ 管理重點

- 虛擬私有網路的建立與使用者帳號的申請，應建立管理程序(變更申請、核准及記錄)
- 定期分析異常事件，例如：VPN使用者簽入失敗
- VPN存取紀錄應即時匯出存檔，並保留足夠的時間

#### ➤ 選購考量

- 可支援的VPN數量或使用者連線數量應滿足機關需求
- 本身應具備防火牆功能，以控管VPN連線的存取
- 與其他不同廠牌產品建立VPN連線的相容性
- 具支援多因子鑑別(Multi-Factor Authentication, MFA)功能



## 7-6 網路安全(13/21)

### ■ 雲端運算-特性

- 隨選自助(On-demand Self-service)
- 廣泛網路存取(Broad Network Access)
- 資源匯聚(Resource Pooling)
- 快速靈活性(Rapid Elasticity)
- 受量測服務(Measured Service)
- 多租用(Multi-tenancy)



## 7-6 網路安全(14/21)

### ■ 雲端運算-服務模式

| 雲端服務模型            | 使用者<br>管理層面                              | 雲端服務供應商<br>管理層面                          |
|-------------------|------------------------------------------|------------------------------------------|
| 基礎設施即服務<br>(IaaS) | 伺服器、儲存、網路、作業系統、中介軟體 (例如資料庫、Web 伺服器)、應用程式 | 硬體 (伺服器、儲存、網路) 的管理及維護                    |
| 平台即服務<br>(PaaS)   | 應用程式、資料                                  | 硬體、作業系統、中介軟體 (例如資料庫、Web 伺服器) 的管理及維護      |
| 軟體即服務<br>(SaaS)   | 應用程式內的使用者設定及資料                           | 硬體、作業系統、中介軟體、應用程式的管理及維護。使用者基本上只需要使用應用程式。 |

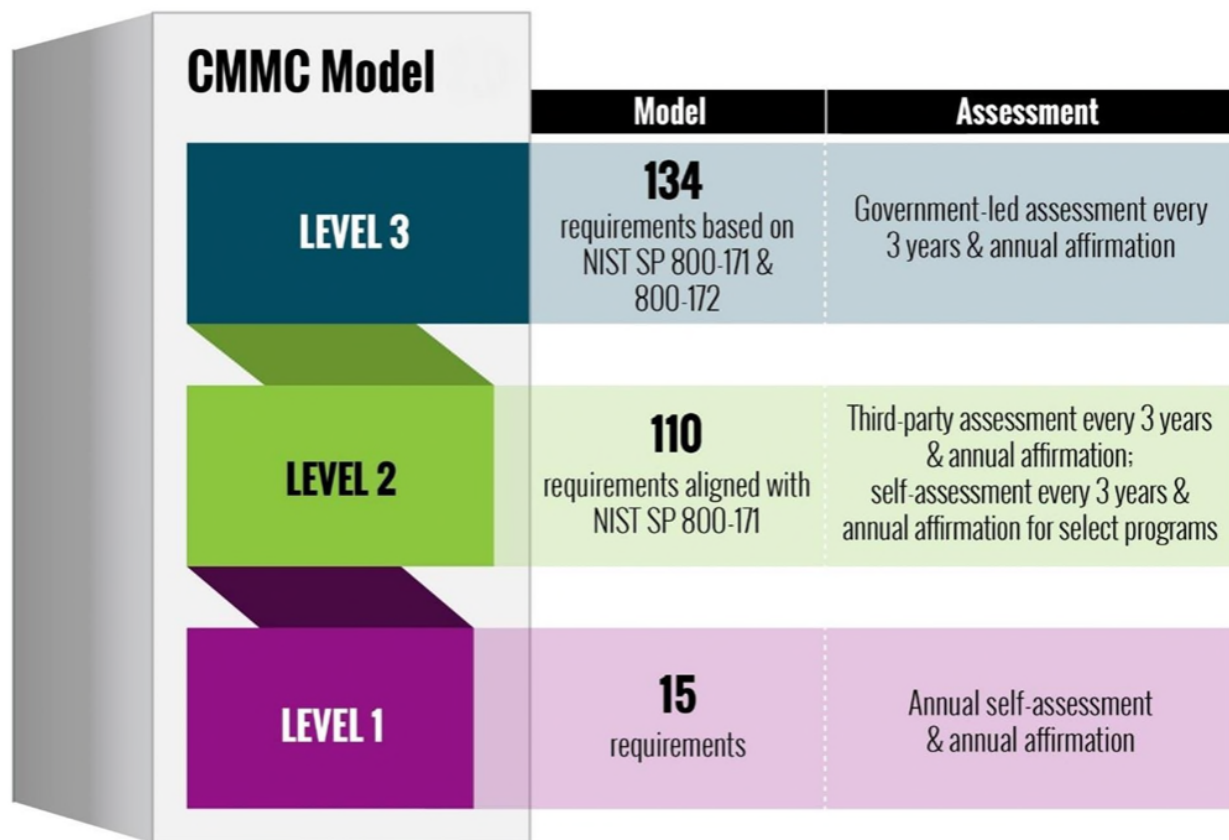


## 7-6 網路安全(16/21)

### ■ 資通安全防護框架

➤ CMMC 2.0 : 2024

網路安全成熟度模型驗證(Cybersecurity Maturity Model Certification, CMMC)



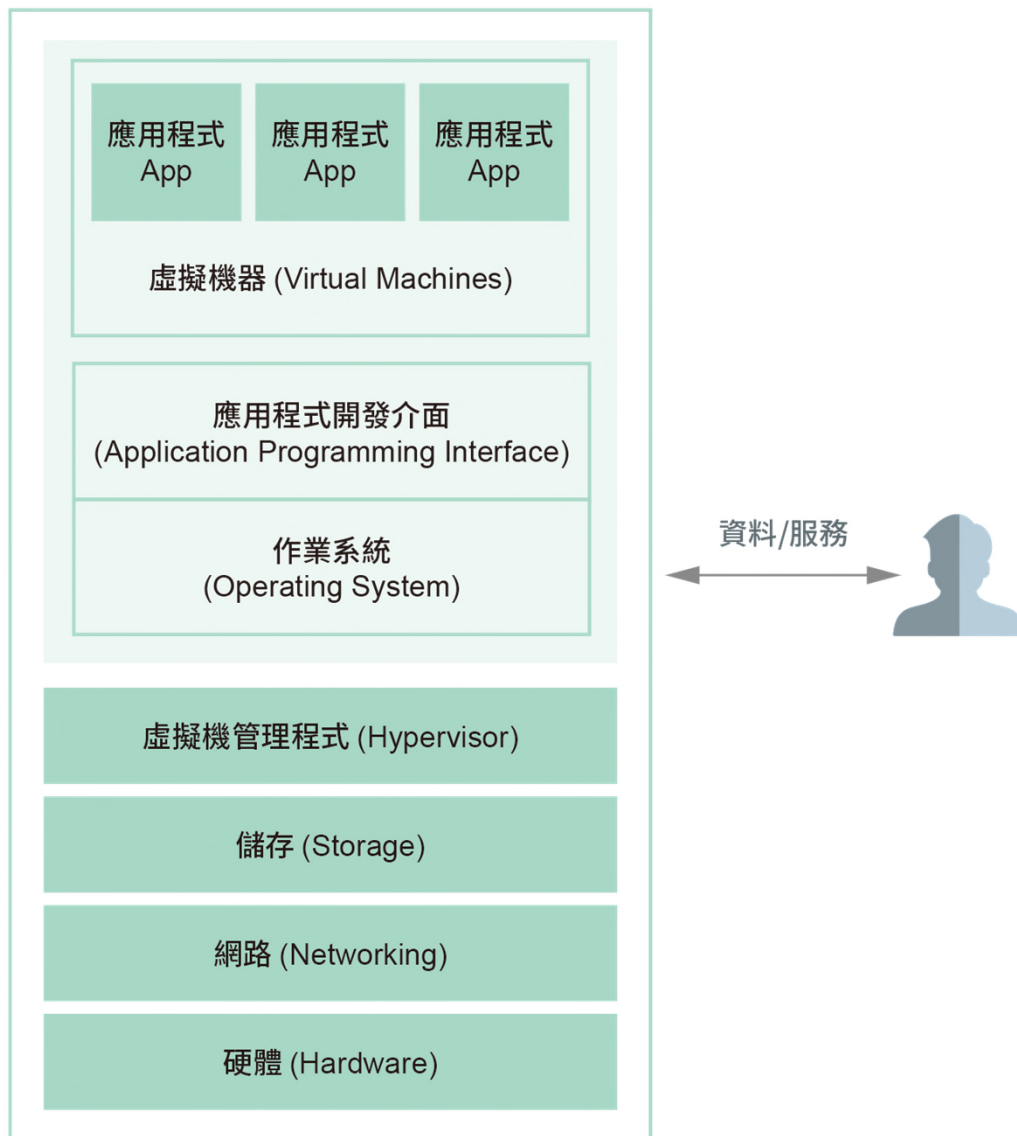




## 7-6 網路安全(17/21)

### ■ 雲端安全管理

➤ NIST SP 800-210

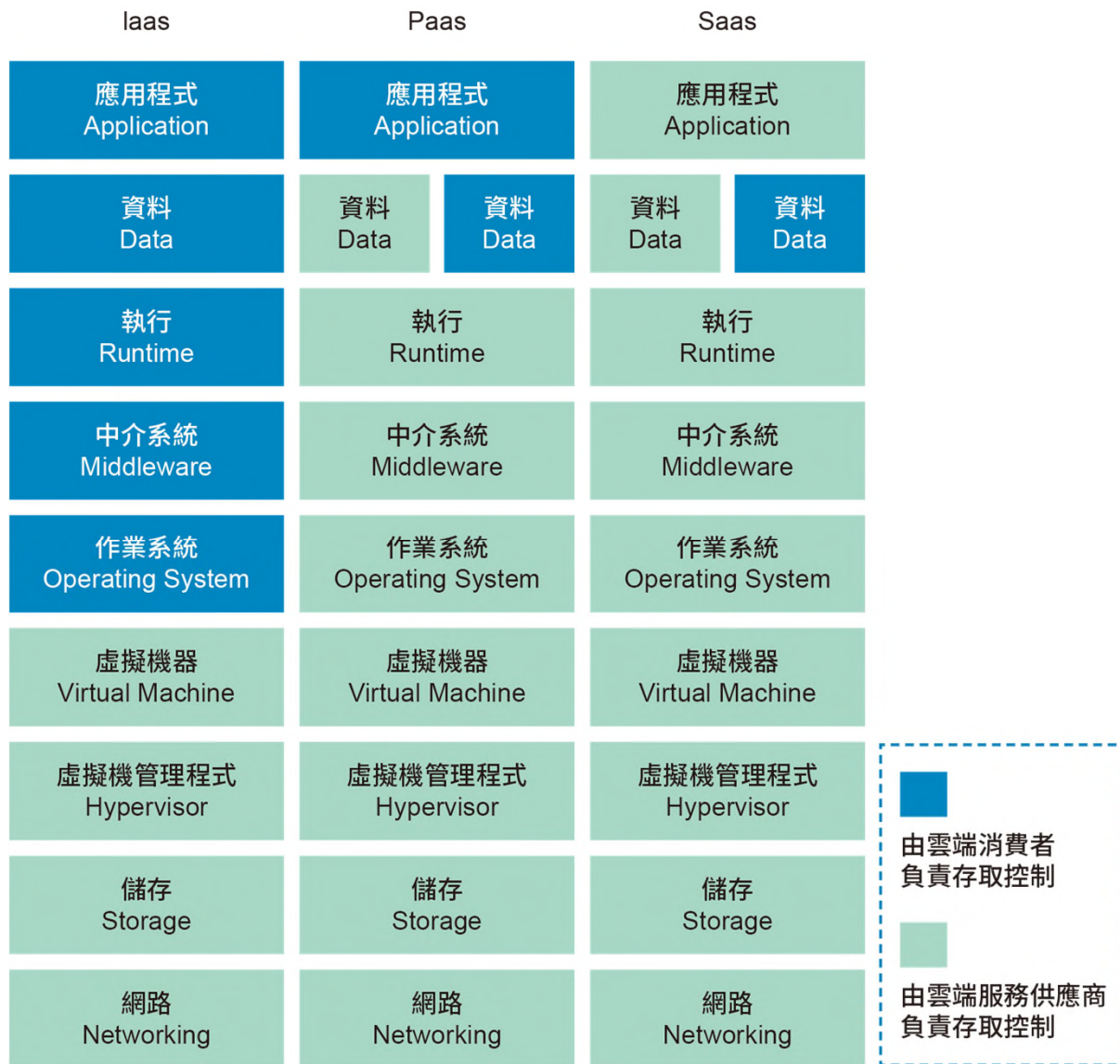




## 7-6 網路安全(18/21)

### ■ 雲端安全管理

➤ NIST SP 800-210





## 7-6 網路安全(19/21)



### ■ 雲端安全管理

➤ ISO/IEC 27017:2015

- 雲端環境下的角色共享與權責
- 雲端服務客戶資產的移除
- 虛擬運算環境的區隔
- 虛擬機器強化
- 管理者的操作安全
- 監控雲端服務
- 虛擬及實體網路安全管理的一致性



## 7-6 網路安全(20/21)

### ■ 雲端運算-資安問題

#### ➤ 客戶端

- 資料竊取
- 資料可用性
- 網路封包竊聽
- 資料內容加密保護
- 共用環境的系統安全防護
- 退租後資料完整刪除

#### ➤ 雲端服務提供者

- 虛擬化環境的系統與網路安全
- 分散式阻斷服務攻擊
- 即時阻絕資安威脅



## 7-6 網路安全(21/21)

### ■ 雲端運算-服務協定

- 雲端提供者與客戶之間會訂定契約(Contract)與服務水準協議 (Service Level Agreement , SLA) , 來規範業者在約定的服務提供期間能達到客戶要求
- 契約明訂業者應該提供的服務以及罰則 , 而服務協定提供的是數值的度量 , 用來客觀的衡量業者提供的特定服務項目是否滿足客戶要求



## 7-7 實體安全(1/17)

### ■ 威脅類型

- 天然環境災害
  - － 水災、颱風、地震、土石流、山崩及極端溫度等
- 供應系統中斷
  - － 電力、通訊、瓦斯及水等
- 人為的破壞
  - － 火災、非授權入侵、破壞、偷竊、爆裂物及員工疏失
- 政治事件
  - － 抗議團體與恐怖組織



## 7-7 實體安全(2/17)

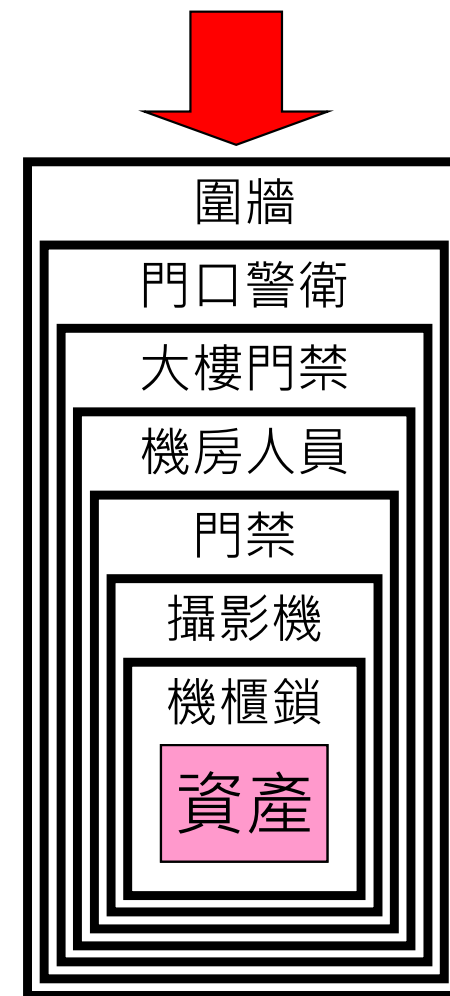
### ■ 防護措施規劃(1/3)

#### ➤ 「嚇阻」犯罪發生

- 圍牆、警衛、警告標語及狗
- 夠大聲的警報器
- 加強警衛巡守頻率
- 布建全時攝影系統
- 公布違反實體控管要求人員姓名
- 簽署認同相關實體控管規範
- 訂定相關罰則

#### ➤ 「延遲」入侵時間

- 門鎖、隔間、人員及標示牌
- 階層式的防護設計，從門口到重要資產需要經過層層關卡



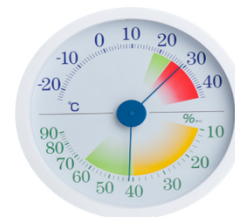


## 7-7 實體安全(3/17)

### ■ 防護措施規劃(2/3)

#### ➤ 「偵測」實體威脅

- 門窗開啟偵測
- 紅外線進出感應
- 動作感應器
- 煙霧偵測器
- 溫濕度偵測



#### ➤ 「評估」事件狀態

- 警衛緊急處理標準程序



#### ➤ 「處理」回復正常作業

- 處理人員或組織
- 相關緊急處理程序
- 聯絡與通報程序(警察、消防及醫療人員)

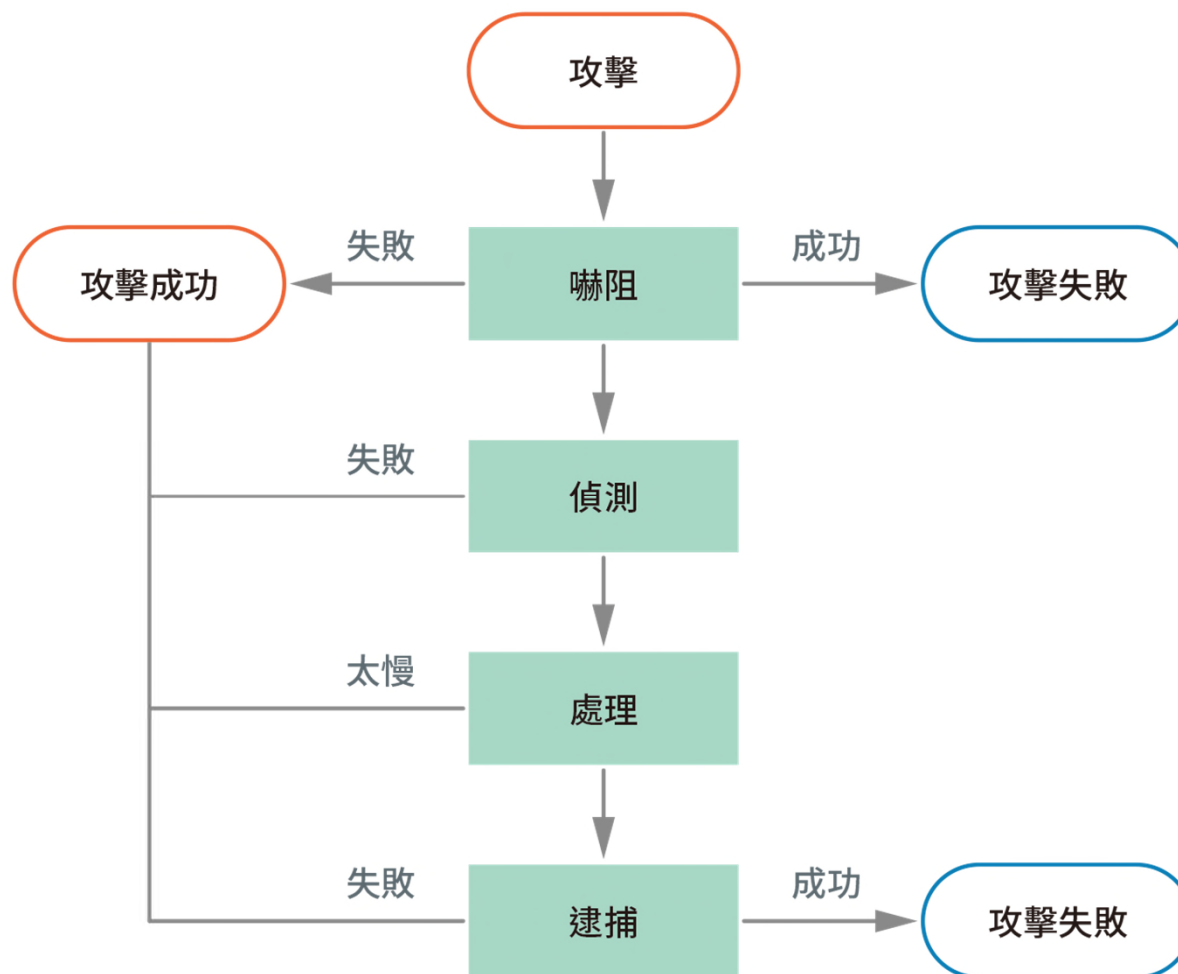




## 7-7 實體安全(4/17)

### ■ 防護措施規劃(4/4)

➤ 縱深防禦的脆弱環節在哪裡？

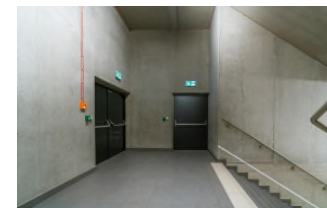




## 7-7 實體安全(5/17)

### ■ 進出控管(1/2)

- 進出口(需要控管的地方)
  - 主要與次要進出口(大門/側門)
  - 緊急疏散出口
  - 車輛與貨物進出口
  - 屋頂、維護孔及窗
- 進出識別
  - 有相片的識別證，由警衛檢查
  - 生物特徵辨識
  - 持有卡片識別
  - 門禁卡及PIN碼雙重鑑別

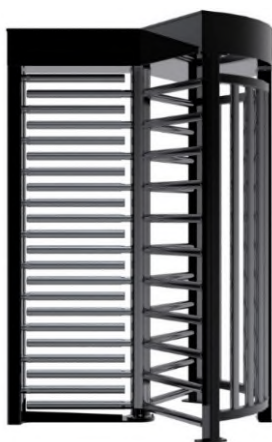




## 7-7 實體安全(6/17)

### ■ 進出控管(2/2)

- 尾隨進出
  - 非授權人員跟隨授權人員一起進出
- 防範尾隨進出
  - 警衛與人員的訓練與認知
  - 旋轉門、驗票匣門
  - Mantrap+ 警衛或內外門的鑑別機制



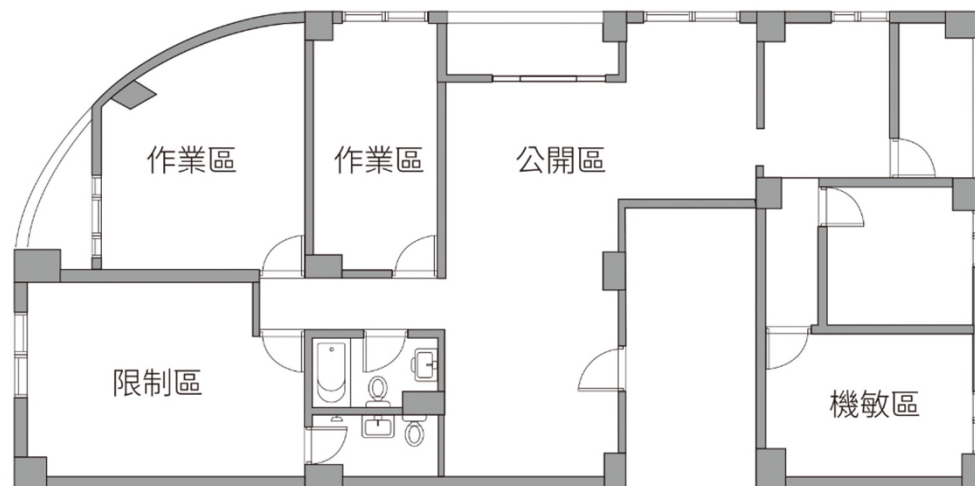


## 7-7 實體安全(7/17)

### ■ 安全區域規劃(1/2)

#### ➤ 需要加強保護的區域

- 電腦資訊設備機房
- 儲存媒體存放室
- 電力與空調設備機房
- 電話與資料線路配接室
- 監控與錄影機房
- 管道間



#### ➤ 安全區域劃分

- 空間規劃應依不同安全等級劃分為不同區域
- 應在規劃圖面上清楚標示該區域為「控管」、「限制」、「公開」或「機敏」



## 7-7 實體安全(8/17)

### ■ 安全區域規劃(2/2)

#### ➤ 安全偵測與滅火器位置規劃

- 煙霧偵測器應置於天花板下風處
- 滅火器應置於容易取得的位置
- 門窗開啟感應器
- 動作感應器



#### ➤ 安全區域等級較高的隔間

- 應採用足夠強度的牆面
- 確定牆面由實際建物樓地板連接到天花板
- 通風口應加裝鐵網





## 7-7 實體安全(9/17)

### ■ 監視錄影

#### ➤ 監視錄影系統的類型

- 單純錄影
- 動作偵測功能
- 行為分辨
- 身分識別

#### ➤ 選擇合適的錄影系統應考慮

- CCTV的目的(偵測/行為/識別)
- CCTV攝影機的放置環境(室內/室外)
- 需要監視錄影的區域(數量?)
- 監視錄影區域的照明(需要紅外線?)
- 儲存空間與保存期限需求
- 與其他安全系統的整合需求







## 7-7 實體安全(10/17)

### ■ 實體安全-空調規劃

#### ➤ 空調系統的功能

- 溫度調節：機房區域與人員作業需求不同
- 濕度調節：濕度太高容易使設備生鏽，濕度太低容易產生靜電(理想的相對濕度應控制在40%~60%)
- 換氣功能：保持空氣新鮮與流通

#### ➤ 空調系統規劃

- 安全區域應維持正風壓，也就是開門時風要往外吹(目的是讓煙霧與不好的氣體向外流動)
- 保護進氣口(避免惡意污染)
- 自動偵煙與自動關閉機制
- 緊急手動關閉開關(當火災或發現不良的氣體在室內散播時)
- 獨立的電力供應線路
- 文件描述維護程序



## 7-7 實體安全(11/17)

### ■ 實體安全-電力來源

#### ➤ 主要電力來源

- 供應日常電力
- 必要時由變電所提供專屬電力供應

#### ➤ 次要電力來源

- 當主要電力來源中斷時使用之電力(例如:發電機)
- 必要時由額外的變電所提供電力







## 7-7 實體安全(12/17)

### ■ 實體安全-電力備援

#### ➤ 不斷電系統(UPS)

##### – 在線式

- 不論市電是否正常，電力的供應會通過UPS系統
- 當電力中斷時無需切換
- 電力的供應較為穩定
- 適合對電力供應品質要求較嚴格的使用者

##### – 非在線式

- 平時電力的供應並不會通過UPS系統，只有當市電供應中斷時，設備的電力供給來源才會切換至UPS系統，持續供應電力





## 7-7 實體安全(13/17)

### ■ 實體安全-電力干擾

- 電力供應常受到外部環境的干擾而導致電力供應不穩定
- 電力供應不穩定將導致
  - 設備故障(突然的高電壓)
  - 設備運作不正常(突然的低電壓)
  - 系統效能降低(持續低電壓)
  - 瞬間資料遺失(電力不穩定)
- 電力供應的狀態應被偵測與記錄
  - 以掌握供電來源的品質
  - 作為改善供電的依據
- 電力干擾來源
  - 閃電、高壓電塔、電纜線、電器用品等





## 7-7 實體安全(14/17)

### ■ 實體安全-靜電防範

#### ➤ 防止靜電危害的方法

- 在機房使用抗靜電高架地板
- 使用抗靜電桌面
- 建築物、機房、電力設備及電腦設備要正常的接地
- 空調維持在合適的濕度
- 在機房中不使用地毯，若有必要請使用抗靜電的地毯
- 在組裝或拆解電腦硬體時戴上抗靜電帶





## 7-7 實體安全(15/17)

### ■ 實體安全-滅火方式(1/2)

#### ➤ 火由下列四種因素所組成

- 可燃物：木材與油
- 溫度超出燃點
- 氧氣
- 化學反應

#### ➤ 滅火的方式

- 降低溫度
- 去除可燃物
- 去除氧氣
- 瓦解燃燒的化學反應





## 7-7 實體安全(16/17)

### ■ 實體安全-滅火方式(2/2)

➤ 不同的可燃物必須採用適合的滅火方式

| 火災分類 | 別名   | 可燃物                 | 滅火方式                         |
|------|------|---------------------|------------------------------|
| A    | 普通火災 | 木材、紙張、衣服及塑膠等        | 水、ABC類乾粉、泡沫之滅火器              |
| B    | 油類火災 | 石油、焦油、油、溶劑、酒精及液態瓦斯等 | BC類或ABC類乾粉、泡沫、CO2、FM-200之滅火器 |
| C    | 電氣火災 | 電器設備、電路及電纜等         | BC 類或 ABC 類乾粉、CO2、FM-200之滅火器 |
| D    | 金屬火災 | 鎂、鈉及鉀等              | 乾粉(特殊滅火藥劑)                   |



## 7-7 實體安全(17/17)

### ■ 實體安全-漏水偵測

- 消防灑水系統可能會有漏水的問題
- 機房無法灑水時，需裝設特殊滅火裝置
- 水的偵測可避免損害
  - 設備
  - 鋪設地板
  - 牆
  - 電腦
  - 建物基礎
- 偵測水的位置
  - 高架地板下
  - 天花板





## 第7單元-分組討論

1. 目前機關是如何規劃及執行弱點掃描及滲透測試？在實際操作中，您認為進行弱點掃描及滲透測試時，最常遇到的挑戰是什麼？是否有任何實務上的建議可以分享？
2. 機關在進行資通安全健診後，如何將發現的問題轉化為具體的改進措施？在改進過程中，您認為最大的困難點是什麼？如何確保資安改進措施能有效落地並長期維持？
3. 在應用程式開發生命週期中，若要從源頭導入安全機制，應如何確保應用程式在設計、開發、測試及部署各階段都符合資安要求？請分享機關或所知悉的應用程式安全最佳實踐，例如，如何將安全考慮融入開發流程中？
4. 目前機關是否有使用雲端服務？若有，主要採用 IaaS、PaaS 或 SaaS 中的哪種模式？請分享在機關所採用的雲端服務模式下，雲端供應商與機關之間的安全責任界線為何？在實際操作中，這種責任劃分是否清晰？是否有任何模糊地帶或潛在的溝通挑戰？





# 第8單元

## 資訊委外安全管理





## 第8單元學習目標

- 8-1 了解資訊委外之相關法規
- 8-2 了解資訊委外之類別及形態
- 8-3 了解資訊委外之風險
- 8-4 了解資訊委外之生命週期
- 8-5 了解資訊委外之資安要求



## 8-1 資訊委外之相關法規(1/4)

### ■ 資通安全管理法第10條：

公務機關或特定非公務機關，於本法適用範圍內，委外辦理資通系統之建置、維運或資通服務之提供，應選任適當之受託者，要求受託者建立有效之資通安全管理機制，並監督該機制之實施。

### ■ 資通安全管理法施行細則第7條第1項：

各機關依本法第十條規定委外辦理資通系統之建置、維運或資通服務之提供(以下簡稱受託業務)，選任及監督受託者時，應注意下列事項

### ■ 資通安全管理法施行細則第9條第1項第11款：

資通安全維護計畫應包含資通系統或服務委外辦理之管理措施

### ■ 資通安全責任等級分級辦法第11條第2項：

各機關自行或委外開發之資通系統應依附表九所定資通系統防護需求分級原則完成資通系統分級，並依附表十所定資通系統防護基準執行控制措施。



## 8-1 資訊委外之相關法規(2/4)

### ■ 資通安全管理法施行細則第7條第1項：

#### 資通安全管理法施行細則

各機關依本法第十條規定委外辦理資通系統之建置、維運或資通服務之提供（以下簡稱受託業務），選任及監督受託者時，應注意下列事項：

- 一、受託者應配置充足且經適當之資格訓練、擁有資通安全專業證照或具有類似業務經驗之資通安全專業人員。
- 二、受託者辦理受託業務得否複委託、得複委託之範圍與對象，及複委託之受託者應具備之資通安全維護措施。
- 三、受託業務涉及國家機密者，執行受託業務之相關人員應接受適任性查核，並依國家機密保護法之規定，管制其出境。
- 四、受託業務包括客製化資通系統開發者，受託者應提供該資通系統之安全性檢測證明；該資通系統屬委託機關之核心資通系統，或委託金額達新臺幣一千萬元以上者，委託機關應自行或另行委託第三方進行安全性檢測；涉及利用非受託者自行開發之系統或資源者，並應標示非自行開發之內容與其來源及提供授權證明。
- 五、受託者執行受託業務，違反資通安全相關法令或知悉資通安全事件時，應立即通知委託機關及採行之補救措施。
- 六、委託關係終止或解除時，應確認受託者返還、移交、刪除或銷毀履行契約而持有之資料。
- 七、受託者應採取之其他資通安全相關維護措施。
- 八、委託機關應定期或於知悉受託者發生可能影響受託業務之資通安全事件時，以稽核或其他適當方式確認受託業務之執行情形。

委託機關辦理前項第三款之適任性查核，應考量受託業務所涉及國家機密之機密等級及內容，就執行該業務之受託者所屬人員及可能接觸該國家機密之其他人員，於必要範圍內查核有無下列事項



## 8-1 資訊委外之相關法規(3/4)

- **第三方稽核：**《資通安全管理法施行細則》第7條第1項第8款
  - 委託機關應定期或於知悉受託者發生可能影響受託業務之資通安全事件時，以稽核或其他適當方式確認受託業務之執行情形。
    - 委託機關對於委外廠商之管理措施，應確保委託業務如期如質執行。
    - 委託機關應檢視所有委外廠商，若囿於人力或經費不足無法每年確認所有委外廠商受託業務辦理情形，建議參照委外金額、涉及核心系統及業務性質等項面擬定相關計畫，並以書面稽核或其他適當方式，確認受託業務執行狀況。
    - 委託機關應留存監督(稽核)結果紀錄、委外廠商之改善報告、以及後續追蹤紀錄
    - 委託機關可參考行政院111年5月26日院臺護字第1110174630號函訂定「資通系統籌獲各階段資安強化措施」



## 8-1 資訊委外之相關法規(4/4)

### ■ 政府資訊作業委外資安參考指引

| 編號 | 文件名稱                                             | 編號 | 文件名稱                     |
|----|--------------------------------------------------|----|--------------------------|
| 1  | 行政院公共工程委員會與數位發展部研訂之「資訊服務採購作業指引」                  | 5  | 行政院公共工程委員會「投標廠商聲明書範本」    |
| 2  | 行政院公共工程委員會與數位發展部研訂之「政府資訊服務採購經費估算編列手冊」            | 6  | 行政院公共工程委員會「投標須知範本」       |
| 3  | 行政院公共工程委員會與數位發展部研訂之「各類資訊(服務)採購之共通性資通安全基本要求參考一覽表」 | 7  | 行政院公共工程委員會「資訊服務採購契約範本」   |
| 4  | 國家資通安全研究院「政府資訊作業委外資安參考指引」                        | 8  | 行政院公共工程委員會「資訊雲端服務採購契約範本」 |



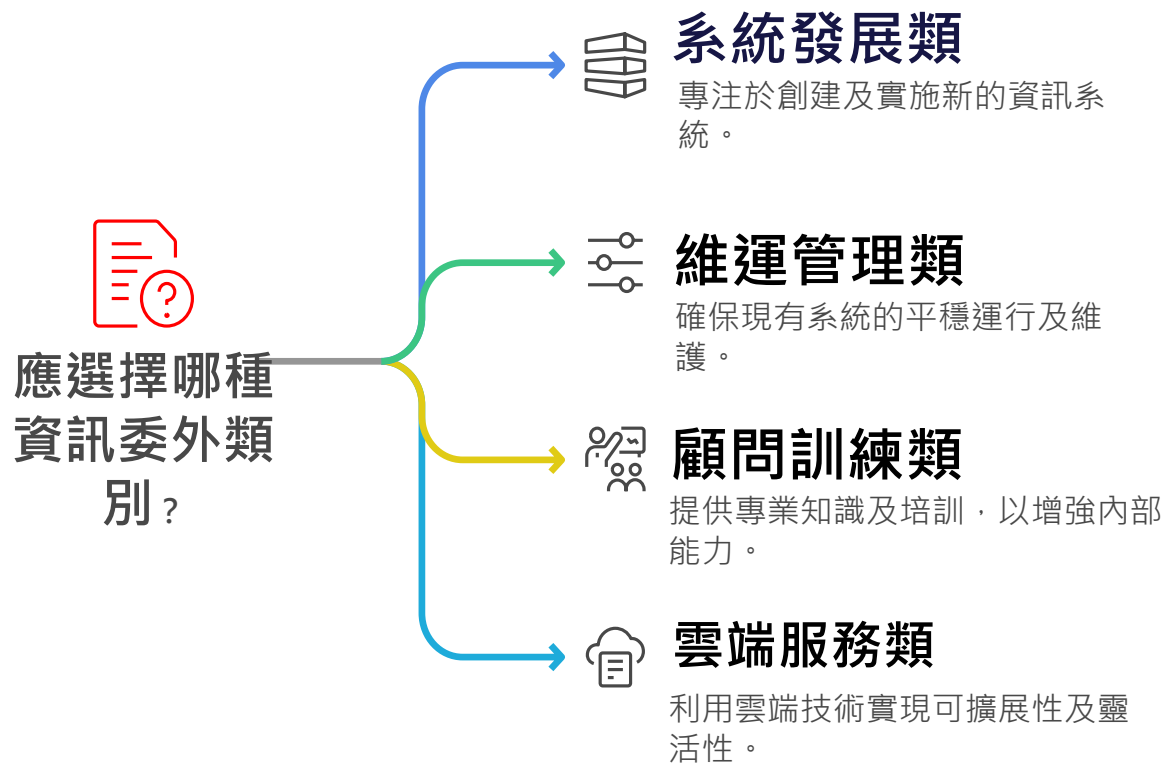
## 8-2 資訊委外之類別及形態(1/2)

### ■ 委外定義

將機關之資通服務所有相關活動，部分或全部由機關外之資通服務提供者完成。

### ■ 資訊委外類別

- 系統發展類
- 維運管理類
- 顧問訓練類
- 雲端服務類

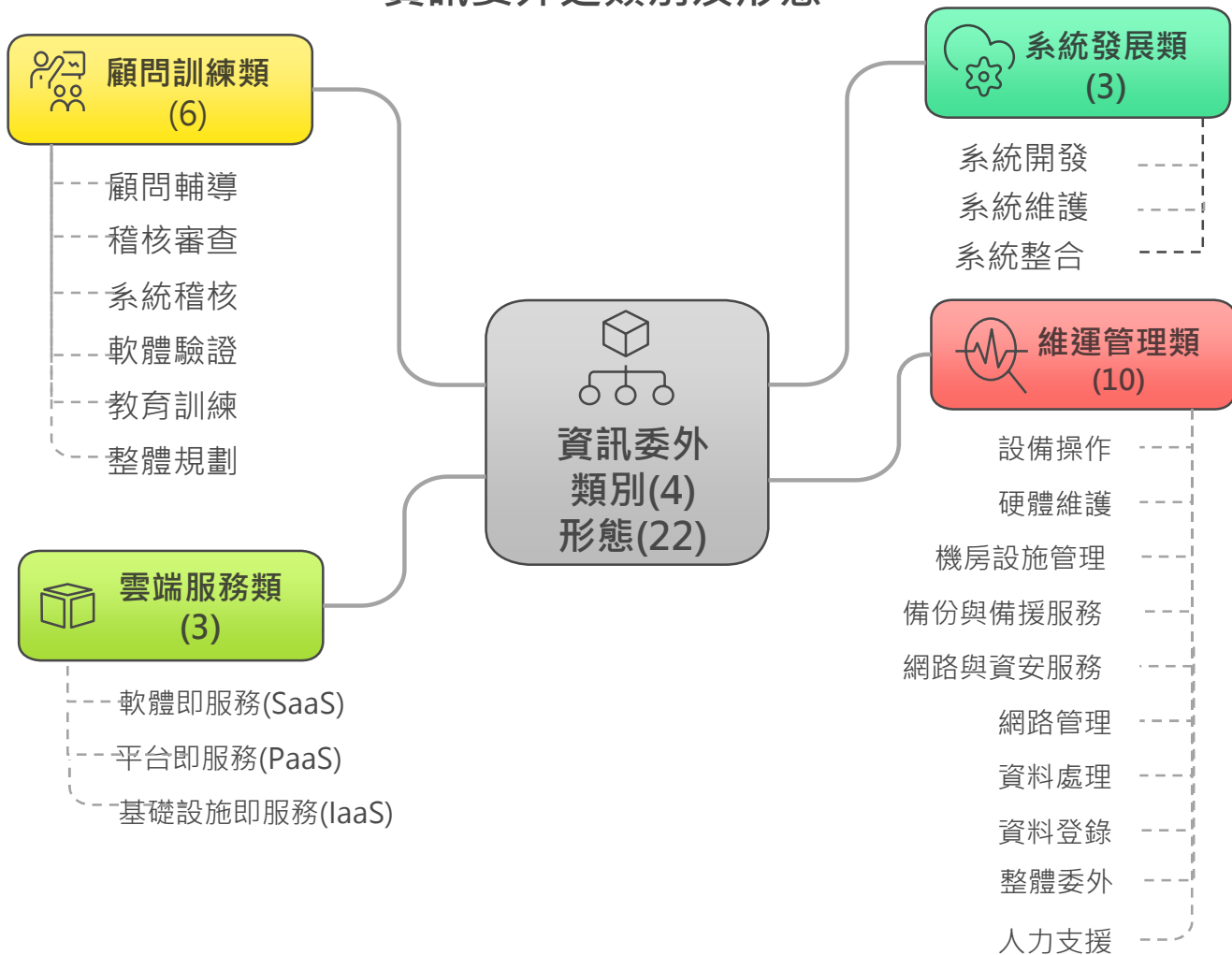






## 8-2 資訊委外之類別及形態(2/2)

資訊委外之類別及形態





## 8-3 資訊委外之風險

### ■ 遠端維運

- 近期迭發生機關開放委外廠商自遠端進行資通系統維護致存取機制遭駭客利用，間接攻擊機關資通系統事件，為降低資安風險，各機關應加強遠端存取控制機制。
- 各機關開放機關內部同仁及委外廠商進行遠端維護資通系統，應採「原則禁止、例外允許」方式辦理，若機關因地 理限制、處理時效及專案特性等因素，須開放前揭人員自遠端存取資通系統時，應至少辦理下列防護措施：
  - 依資通安全管理法施行細則第7條及資通安全責任等級分級辦法附表十中有關遠端存取相關規定辦理，並建立及落實管理機制。
  - 開放遠端存取期間原則以短天期為限，並建立異常行為管理機制。
  - 於結束遠端存取期間後，應確實關閉網路連線，並更換遠端存取通道(如 VPN)登入密碼。





## 8-4 資訊委外之生命週期(1/2)

### ■ 決定需求

機關對資通系統明確定義需求，並識別出資通安全的需求。此階段對應資訊委外資安要求之計畫階段

### ■ 識別可行解決方案

在建置或選商前，審慎分析資訊作業環境現況與期望達成目標之差異，再識別出可行解決方案選項，並訂定適當的評估指標。此階段仍是對應資訊委外資安要求之計畫階段



## 8-4 資訊委外之生命週期(2/2)

### ■ 選定解決方案

由決策者選出適當的解決方案。此階段對應資訊委外資安要求之決標階段

### ■ 完成建置

於完成決標後，成立專案組織，督導服務廠商遵循RFP與契約，如期如質完成系統建置與測試工作。此階段對應資訊委外資安要求之履約管理階段

### ■ 確認營運服務正常

服務進入營運狀態，需持續量測服務水準是否滿足原規劃需求，此階段對應資訊委外資安要求之驗收階段



## 8-5 資訊委外之資安要求(1/12)

■ 依一般採購流程區分成以下階段，並提出各階段應有之資安控管建議，以確保資訊委外之資通安全

- 計畫階段
- 招標階段
- 決標階段
- 履約管理階段
- 驗收階段
- 保固階段

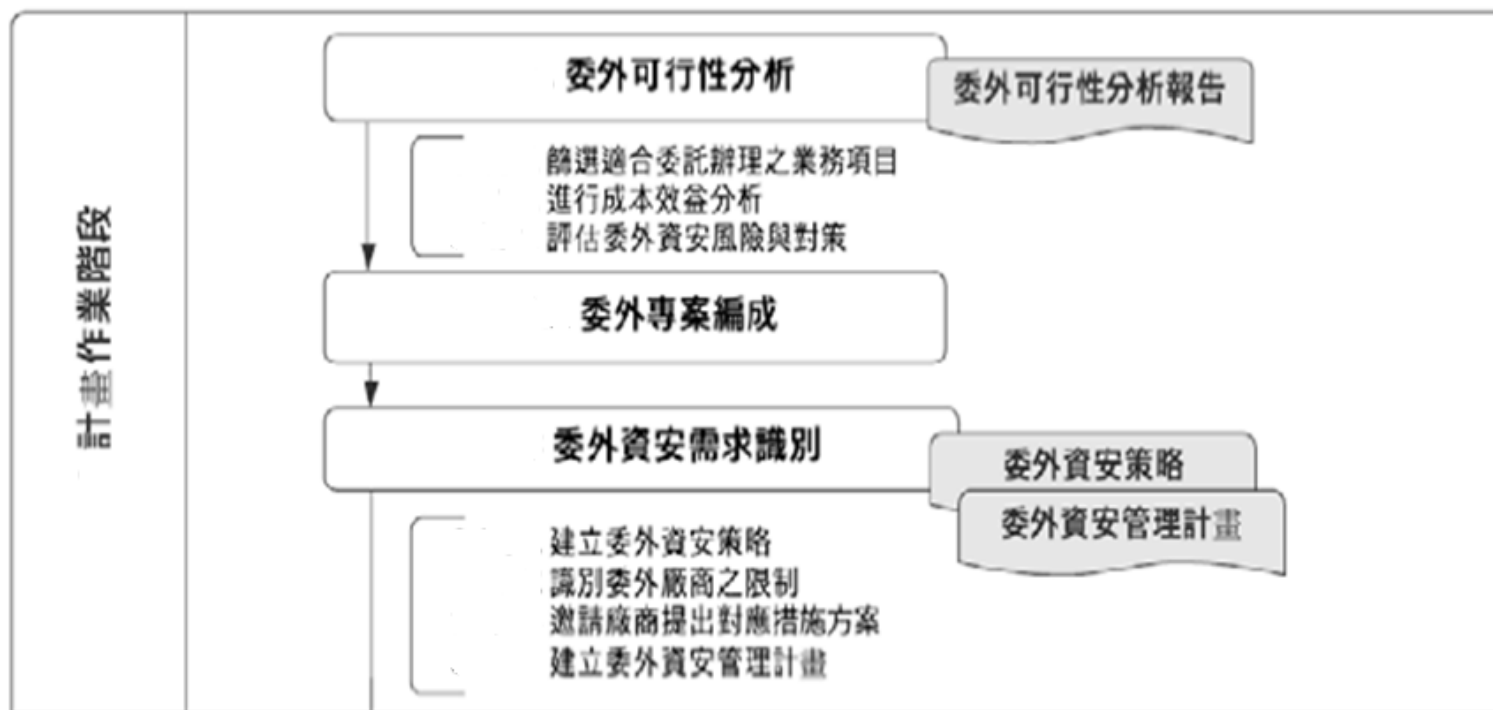
|   |        |
|---|--------|
| 1 | 計畫階段   |
| 2 | 招標階段   |
| 3 | 決標階段   |
| 4 | 履約管理階段 |
| 5 | 驗收階段   |
| 6 | 保固階段   |



## 8-5 資訊委外之資安要求(2/12)

### ■ 計畫階段(1/3)

- 計畫階段重點在評估個案之委外可行性與委外風險，以確認是否進行委外
- 區分成「委外可行性分析」、「委外專案編成」及「委外資安需求識別」三步驟





## 8-5 資訊委外之資安要求(3/12)

### ■ 計畫階段(2/3)

#### ➤ 資訊委外可行性分析

- － 篩選適合委託辦理之業務項目
- － 進行成本效益分析
- － 評估資訊委外資安風險與對策
  - 本步驟屬於初期風險評估，在有限資訊與資源下，可採高階風險評鑑以得出風險值，並制定降低風險之對策
  - 當所識別之資安風險無法降低至可接受風險等級時，不宜取得此項產品或服務
  - 如風險值較高時，機關宜在簽訂委外契約前，進行詳細風險評鑑，以確保更精確之風險得以被辨識

#### ➤ 委外專案編成

- － 應指派對資訊委外專案性質或內容有充分了解能力之專案負責人
- － 視委外性質與規模邀請採購(總務)、法務、會(主)計、業務、資訊及政風等單位人員參與



## 8-5 資訊委外之資安要求(4/12)

### ■ 計畫階段(3/3)

#### ➤ 委外資安需求識別

- 建立資訊委外資安策略
  - 視專案時程定期審查資安策略，或於發生重大營運、法律、法規、架構、政策及契約變更時審查之，確保資安策略讓相關人員知曉(包含委外廠商相關人員)
- 識別委外廠商之限制
  - 視資訊委外產品或服務之本質，考量委外產品與服務是否涉及國家機密、影響國家安全或受WTO政府採購協定之規範，以限制投標廠商或其人員之資格
- 邀請廠商提出對應措施方案
  - 針對各項資通安全需求，經由RFI或RFC等方式徵詢委外廠商提供相對應建議措施
- 建立資訊委外資安管理計畫
  - 對委外個案應具備之資安需求項目進行詳細分析，並將之具體化為資訊委外資安管理計畫，以提供擬訂以下文件之依據
    - \* 徵求建議書文件(詳細陳述對欲採購產品或服務本身資安要求)
    - \* 資訊委外契約書(明訂採購流程中廠商之資安義務與責任)
    - \* 資訊委外服務水準協定(明訂可量測之服務水準)



## 8-5 資訊委外之資安要求(5/12)

### ■ 招標階段

- 招標階段之重點在遴選適宜之委外廠商
- 招標階段作業包含定義委外廠商評估準則、備妥保密協議書、招標文件、蒐集廠商投標文件及評選服務建議書等作業
- 資安管理重點著重在RFP撰寫之完整度與評選準則中之資安要求符合度
- 招標文件之RFP及契約書，應依委外服務之資通系統等級，納入資通系統防護基準之系統發展生命週期(SSDLC)相關規定，包括需求階段、設計階段、開發階段、測試階段、部署與維運階段、委外階段



## 8-5 資訊委外之資安要求(6/12)

### ■ 決標階段

- 決標階段之重點為與廠商之簽約作業
  - 機關與委外廠商雙方依據招標文件與廠商回應之服務建議書進行最終協議，於雙方協議並確定契約內容後，即進行簽約作業
- 簽約行為重點
  - 查核廠商是否完成保密切結
  - 完成專案編組
    - \* 例如：得標廠商於簽約前須依據招標文件規定，提出各項保密切結，並就機關需求規劃資通安全管理措施，廠商專案組織人員之遴選與質量需考量重新調整，並賦予適當職掌，以利承辦單位依據契約執行各項查核，並做成紀錄





## 8-5 資訊委外之資安要求(7/12)

### ■ 履約管理階段(1/2)

#### ➤ 資通安全組織

- 機關與委外廠商皆應指定專案管理人員，負責推動、協調及督導資通安全管理事項

#### ➤ 資訊委外風險持續識別

- 機關資訊委外過程中之資通安全風險，宜在核准廠商存取內部設施前加以識別，並作適當之控制措施
- 若需要允許委外廠商存取機關之資訊處理設施或資訊，宜執行風險評鑑以識別特定控制措施之要求

#### ➤ 資訊委外人力資源安全(僱用前、期間、終止或變更)

- 委外前宜依工作職掌進行人員的篩選
- 委外廠商之作業員工，由個人同意並簽署其僱用同意書，該同意書陳述其與機關對資通安全之責任
- 宜提供資訊委外人員資安程序與資訊處理設施之正確使用認知教育及訓練，以將可能之資安風險降至最低



## 8-5 資訊委外之資安要求(8/12)

### ■ 履約管理階段(2/2)

#### ➤ 資訊委外實體與環境安全

- 防止機關內資訊因資訊委外而遭未經授權的實體存取、損害及干擾，關鍵或敏感的資訊處理設施宜置放於安全區域，並經由適當之安全屏障與進出控制措施加以保護，確保這些設施免受未經授權之存取、損害及干擾

#### ➤ 資訊委外管理

- 資訊委外相關作業應符合機關安全政策與程序、資通系統防護基準之要求

#### ➤ 資訊委外使用者存取管理

- 為確保未經授權之資訊委外人員對資通系統存取，機關宜有正式程序，以控制資通系統與服務的存取權限配置作業
- 程序應從開始登記使用註冊，到最終不再需要存取資通系統與服務註銷

#### ➤ 資訊委外資通安全事件管理

- 機關資訊委外宜備妥正式的事件通報與提報程序，提供委外廠商配合並施予合宜訓練
- 委外廠商宜認知可能對機關資產安全造成衝擊事件與弱點之通報程序，並要求所有人員儘快向指定聯絡點通報任何資通安全事件與弱點



## 8-5 資訊委外之資安要求(9/12)

### ■ 驗收階段(1/3)

#### ➤ 一般驗收程序

- 機關依據契約文件與「履約管理」階段執行成果辦理
- 勞務驗收，得以書面或召開審查會方式辦理，其書面驗收文件或審查會紀錄，得視為驗收紀錄
- 機關可要求委外廠商於簽約後一定時間內提交「專案工作計畫書」，內容確認委外專案之進行方式、專案組織、相關時程及資通安全要求事項是否符合
- 委外廠商也須將定期召開工作進度報告會議之內容，如應完成重要工作項目、已完成工作的項目、預計工作項目、問題與建議等，提供驗收單位佐證



## 8-5 資訊委外之資安要求(10/12)

### ■ 驗收階段(2/3)

#### ➤ 資安驗收內容

##### － 顧問訓練類

- 主要提供管理與技術服務，在完成顧問服務時即可得知是否符合機關要求
- 對於需使用軟體輔助才可完成專案之情況，應確認委外廠商是否使用最適之檢測工具與版本

##### － 系統發展類

- 除功能與效能測試外，應要求委外廠商提供該資通系統之安全性檢測證明
- 資通系統使用非委外廠商自行開發之元件時，宜要求委外廠商揭露第三方程式元件之來源與授權證明，以確保其元件非來自大陸地區或其他限制地區。



## 8-5 資訊委外之資安要求(11/12)

### ■ 驗收階段(3/3)

#### － 維運管理類

- 維運管理類與顧問訓練類之服務類似
- 若維運過程有新發現程式漏洞，則需進行程式修補者或定期進行程式弱點掃描

#### － 雲端服務類

- 雲端服務類與系統發展類相似
- 除確認功能與效能外，對於產品或服務之資安保證大多來自於委外廠商所提供之證明
- 機關應確認與評估雲端服務供應商宣稱之證認範圍，包含控制與評估涵蓋功能及服務

- 當專案結束後，機關應立即停止委外廠商之實體與邏輯存取權限，並回收或請委外廠商銷毀屬於機關之資訊資產，必要時可要求委外廠商出具銷毀證明



## 8-5 資訊委外之資安要求(12/12)

### ■ 保固階段

- 保固服務
  - 保固期間不論軟硬體資產，應以維持驗收完成時之狀態為主要目的
- 異常管理
  - 保固期間運作中之資訊處理設施與應用軟體系統，均應受到嚴格之變更管理控制
    - 若系統有重大資安顧慮或瑕疵，如屬委外廠商責任，需由委外廠商另提變更計畫
  - 保固期間系統如有委外廠商派駐人員協助者，發生異常事件時，應由派駐人員負責將問題反映至資訊業務承辦人員，再循正常程序陳報



## 第8單元-分組討論

1. 機關在辦理資訊委外時，如何依照資安法規要求來選任及監督委外廠商？在落實這些規定時，曾遇到哪些具體挑戰？又採取了哪些應對措施？
2. 請分享機關對於委外廠商執行遠端維護的相關管理政策為何？在實務上如何落實教材中提到的防護措施？是否曾遇過遠端存取導致的資安事件，當時如何處理？
3. 機關認為在計畫階段有效地識別資安需求及進行風險評估為何如此重要？又在此階段會進行哪些具體的資安考量？請分享早期投入資安規劃，對後續委外專案的幫助或經驗。
4. 請討論在撰寫招標文件時，除了功能需求外，應如何明確地列出資訊安全的具體要求？在評選廠商時，如何評估其資安能力及所提出的資安措施是否足夠？簽訂委外契約時，哪些資安相關的條款是不可或缺的？
5. 機關在委外專案執行期間如何具體監督委外廠商遵守資安規定？在驗收時會執行哪些安全測試或文件查核？專案結束後，如何確保機敏資料已確實被廠商回收或銷毀？



# 第9單元

## 資通安全事件通報應變及演練





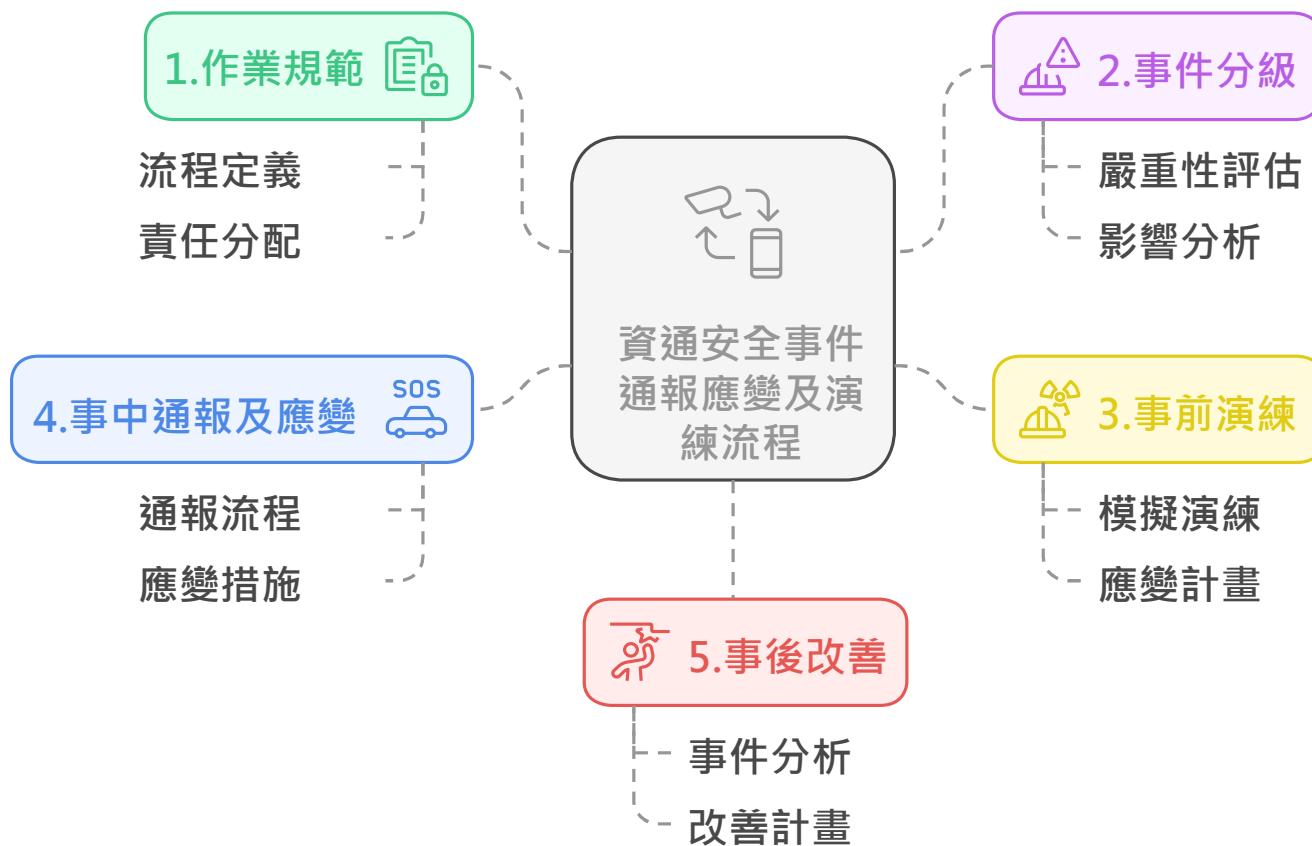
## 第9單元學習目標

- 9-1 了解資通安全事件管理機制
- 9-2 了解資通安全事件通報及應變作業規範
- 9-3 了解資通安全事件等級評估
- 9-4 了解資通安全事件通報及應變作業流程
- 9-5 了解資通安全事件通報應變及演練作業
- 9-6 了解資通安全事件處理
- 9-7 了解數位證據及數位鑑識
- 9-8 了解社交工程



## 9-1 資通安全事件管理機制

- 依資通安全管理法第10條第4項、第17條第4項及第24條第4項訂定
- 目的：為強化各機關資安事件之因應作為
- 管理流程：訂定作業規範、事件之分級、事前之演練、事中之通報及應變，以及事後之改善





## 9-2 資通安全事件通報及應變作業規範

### ■ 通報及應變作業規範

- 各機關應就資通安全事件之通報訂定作業規範，其內容應包括下列事項：  
(§4)
  - 判定事件等級之流程及權責
  - 事件之影響範圍、損害程度及機關因應能力之評估
  - 資通安全事件之內部通報流程
  - 通知受資通安全事件影響之其他機關之方式
  - 前四款事項之演練
  - 資通安全事件通報窗口及聯繫方式
  - 其他資通安全事件通報相關事項
- 各機關應就資通安全事件之應變訂定作業規範，其內容應包括下列事項：  
(§5)
  - 應變小組之組織
  - 事件發生前之演練作業
  - 事件發生時之損害控制機制
  - 事件發生後之復原、鑑識、調查及改善機制
  - 事件相關紀錄之保全
  - 其他資通安全事件應變相關事項



## 9-3 資通安全事件等級評估(1/8)

### ■ 資通安全事件分級由輕至重分「1」、「2」、「3」、「4」四個級別

- 評定資通安全事件分級時，將以資訊或資通系統性質與其CIA衝擊性，綜評該事件級別

| 資訊或資通系統性質                                                           | CIA衝擊性                  | 綜評事件級別               |
|---------------------------------------------------------------------|-------------------------|----------------------|
| 1. (涉及/未涉及CI)核心業務資訊或資通系統<br>2. 非核心業務資訊或資通系統<br>3. 一般公務機密<br>4. 國家機密 | ➤ 機密性<br>➤ 完整性<br>➤ 可用性 | ➤ 以最高級別評為該資通安全事件通報等級 |

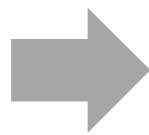
- 一般公務機密(文書處理手冊第51項)：指本機關持有或保管之資訊，除國家機密外，依法令有保密義務者
- 國家機密(國家機密保護法第2條及第4條)：指為確保國家安全或利益而有保密之必要，對政府機關持有或保管之資訊，經依本法核定機密等級者(絕對機密、極機密、機密)



## 9-3 資通安全事件等級評估(2/8)

### ■ 資安事件影響等級評定須考量三面向衝擊性

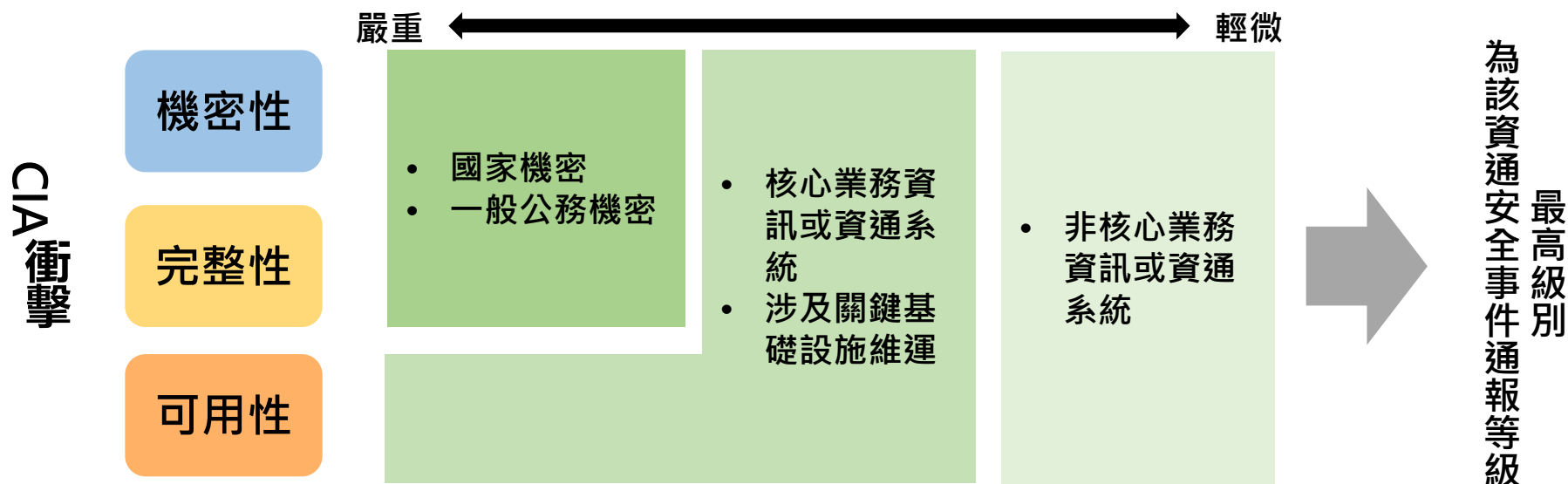
- 「機密性」衝擊
- 「完整性」衝擊
- 「可用性」衝擊



綜合評估資安事件造成之「機密性」、「完整性」及「可用性」衝擊，核判影響等級。

### 資訊或通訊系統性質

(核心、關鍵基礎設施、機密)





## 9-3 資通安全事件等級評估(3/8)

➤ 機密性係依據外洩的資訊性質與程度評估級別

| 影響等級 |     | 說明                                                                      |
|------|-----|-------------------------------------------------------------------------|
| 輕微   | 第1級 | 非核心業務資訊遭 <u>輕微洩漏</u>                                                    |
|      | 第2級 | 非核心業務資訊遭 <u>嚴重洩漏</u> ，或未涉及關鍵基礎設施維運之核心業務資訊遭輕微洩漏                          |
|      | 第3級 | 未涉及關鍵基礎設施維運之核心業務資訊遭 <u>嚴重洩漏</u> ，或一般公務機密、涉及關鍵基礎設施維運之核心業務資訊遭 <u>輕微洩漏</u> |
| 嚴重   | 第4級 | 一般公務機密、涉及關鍵基礎設施維運之核心業務資訊遭 <u>嚴重洩漏</u> ，或國家機密 <u>遭洩漏</u>                 |

➤ **輕微洩漏/嚴重洩漏**：由政府機關依洩漏所造成之影響自行認定其嚴重性



## 9-3 資通安全事件等級評估(4/8)

- 完整性係依據受影響資訊或資通系統性質與竄改程度評估級別

| 影響等級 |     | 說明                                                                                    |
|------|-----|---------------------------------------------------------------------------------------|
| 輕微   | 第1級 | 非核心業務資訊或非核心資通系統 <u>遭輕微竄改</u>                                                          |
|      | 第2級 | 非核心業務資訊或非核心資通系統 <u>遭嚴重竄改</u> ，或未涉及關鍵基礎設施維運之核心業務資訊或核心資通系統遭輕微竄改                         |
|      | 第3級 | 未涉及關鍵基礎設施維運之核心業務資訊或核心資通系統遭 <u>嚴重竄改</u> ，或一般公務機密、涉及關鍵基礎設施維運之核心業務資訊或核心資通系統遭 <u>輕微竄改</u> |
| 嚴重   | 第4級 | 一般公務機密、涉及關鍵基礎設施維運之核心業務資訊或核心資通系統遭 <u>嚴重竄改</u> ，或國家機密 <u>遭竄改</u>                        |

- **輕微竄改/嚴重竄改**：由政府機關依竄改所造成之影響自行認定其嚴重性





## 9-3 資通安全事件等級評估(5/8)

- 可用性係依據受影響資通系統性質與可否於可容忍中斷時間回復評估級別

| 影響等級 |     | 說明                                                                                                                            |
|------|-----|-------------------------------------------------------------------------------------------------------------------------------|
| 輕微   | 第1級 | 非核心資通系統之運作受影響或停頓，於 <u>可容忍中斷時間</u> 內回復正常運作，造成機關日常作業影響                                                                          |
|      | 第2級 | 非核心資通系統之運作 <u>受影響或停頓</u> ，無法於 <u>可容忍中斷時間</u> 內回復正常運作，或未涉及關鍵基礎設施維運之核心資通系統之運作 <u>受影響或停頓</u> ，於 <u>可容忍中斷時間</u> 內回復正常運作           |
|      | 第3級 | 未涉及關鍵基礎設施維運之核心資通系統之運作 <u>受影響或停頓</u> ，無法於 <u>可容忍中斷時間</u> 內回復正常運作，或涉及關鍵基礎設施維運之核心資通系統之運作 <u>受影響或停頓</u> ，於 <u>可容忍中斷時間</u> 內回復正常運作 |
| 嚴重   | 第4級 | 涉及關鍵基礎設施維運之核心資通系統之運作 <u>受影響或停頓</u> ，無法於 <u>可容忍中斷時間</u> 內回復正常運作                                                                |

- **可容忍中斷時間**：政府機關應考量業務性質及影響程度等因素，評定可容許的中斷時間





## 9-3 資通安全事件等級評估(6/8)

| 影響等級 | 機密性<br>業務資訊洩漏       |      | 完整性<br>業務資訊/資通系統遭竄改        |      | 可用性<br>資通系統運作受影響或停頓 |              |
|------|---------------------|------|----------------------------|------|---------------------|--------------|
|      | 資訊                  | 影響程度 | 資訊/<br>資通系統                | 影響程度 | 資通系統                | 可否於可容忍中斷時間回復 |
| 第1級  | 非核心業務資訊             | 輕微   | 非核心業務資訊<br>或非核心資通系統        | 輕微   | 非核心資通系統             | 可            |
| 第2級  | 非核心業務資訊             | 嚴重   | 非核心業務資訊<br>或非核心資通系統        | 嚴重   | 非核心資通系統             | 不可           |
|      | 核心業務資訊<br>(未涉及CI維運) | 輕微   | 核心業務資訊或核心資通系統<br>(未涉及CI維運) | 輕微   | 核心資通系統<br>(未涉及CI維運) | 可            |
| 第3級  | 核心業務資訊<br>(未涉及CI維運) | 嚴重   | 核心業務資訊或核心資通系統<br>(未涉及CI維運) | 嚴重   | 核心資通系統<br>(未涉及CI維運) | 不可           |
|      | 核心業務資訊<br>(涉及CI維運)  | 輕微   | 核心資通系統<br>(涉及CI維運)         | 輕微   | 核心資通系統<br>(涉及CI維運)  | 可            |
|      | 一般公務機密              | 輕微   | 一般公務機密                     | 輕微   |                     |              |
| 第4級  | 核心業務資訊<br>(涉及CI維運)  | 嚴重   | 核心業務資訊或核心資通系統<br>(涉及CI維運)  | 嚴重   | 核心資通系統<br>(涉及CI維運)  | 不可           |
|      | 一般公務機密              | 嚴重   | 一般公務機密                     | 嚴重   |                     |              |
|      | 國家機密                | -    | 國家機密                       | -    |                     |              |



## 9-3 資通安全事件等級評估(7/8)

### 情境

A機關自行發現內部一名員工電腦中的檔案被加密，此該員工負責處理機關內核心資通系統相關行政作業，該系統未涉及關鍵基礎設施相關運作，但可以用其他電腦代替使用，並未造成資料外洩情形。A機關資訊人員針對受駭電腦進行還原程序處理，並清查其餘電腦，沒有被加密之情形。A機關資訊人員依通報應變作業規定登入通報應變網站進行通報作業

### 解析

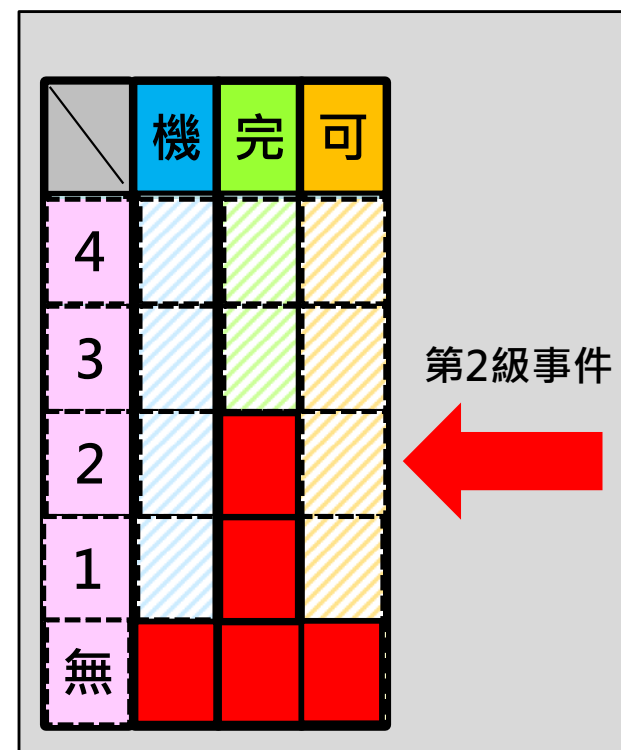
機密性：因此次事件未造成資料外洩情形，選擇「無需通報」

完整性：此電腦為核心業務使用，其系統已遭變更竄改，故選擇「第2級」

可用性：因此次於事件無系統或設備運作受影響，故選擇「無需通報」

### 綜合評估

因第二項目為「第2級事件」，第一、三項目為「無需通報」，故綜合評估此資安事件為「第2級事件」。





## 9-3 資通安全事件等級評估(8/8)

|      |                                                                                                                                                                                                                            |  |  |
|------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|--|
| 情境   | B機關製程資料收集系統為負責關鍵基礎設施運作團隊存放執行紀錄系統，每日進行備份，資料處理人員發現系統無法正常開啟，經查發現製程資料收集系統遭植入KillDisk程式刪除主機的主要啟動磁區(MBR)與系統資料，事件發生後，處理人員透過備份還原機制，將前日資料還原，並由各執行團隊重新匯入當日執行紀錄                                                                       |  |  |
| 解析   | <p>機密性：因此次資料收集系統未造成資料外洩情形，選擇「無需通報」</p> <p>完整性：資料收集系統被植入一惡意程式，系統主要存放關鍵基礎設施業務執行團隊相關紀錄，故判定為<b>涉及關鍵基礎設施維運之核心資通系統遭嚴重竄改</b>，故選擇「第4級」</p> <p>可用性：資料收集系統透過備份機制復原，判定為<b>涉及關鍵基礎設施維運之核心資通系統之運作受影響或停頓，於可容忍中斷時間內回復正常運作</b>，故選擇「第3級」</p> |  |  |
| 綜合評估 | 因第一項目為「無需通報」，第二項目為是「第4級」，第三項目為「第3級」，故綜合評估此資安事件為「第4級事件」                                                                                                                                                                     |  |  |

|   | 機 | 完 | 可 |
|---|---|---|---|
| 4 |   |   |   |
| 3 |   |   |   |
| 2 |   |   |   |
| 1 |   |   |   |
| 無 |   |   |   |

第4級事件



## 9-4 資通安全事件通報及應變作業流程(1/5)

### ■ 資安事件處理之相關訊息

#### 資安事件通報 基本項目

- 發生機關
- 發生或知悉時間
- 狀況之描述
- 等級之評估
- 因應事件所採取之措施
- 外部支援需求評估
- 其他相關事項

#### 損害控制 內容

- 根據機關內部處理資安事件之程序，記錄損害控制或復原之歷程

#### 調查、處理 及改善報告

- 事件發生或知悉其發生、完成損害控制或復原作業之時間
- 事件影響之範圍及損害評估
- 損害控制及復原作業之歷程
- 事件調查及處理作業之歷程
- 事件根因分析
- 為防範類似事件再次發生所採取之管理、技術、人力或資源等層面之措施
- 預定完成時程及成效追蹤機制



## 9-4 資通安全事件通報及應變作業流程(2/5)

### ■ 通報及應變作業流程(1/2)

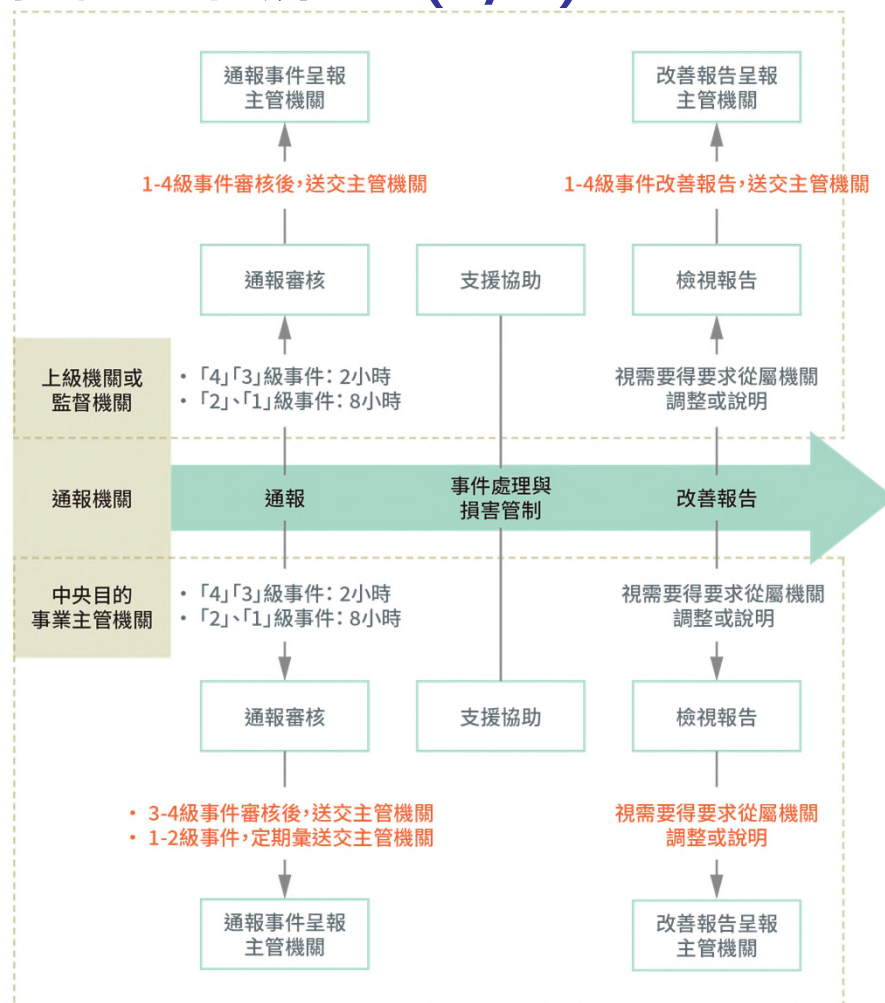
- 公務機關/特定非公務機關應於知悉資安事件後，**1小時**內向上(主管機關/中央目的事業主管機關)通報相關事件相關資訊，並於限定時間內，儘速完成損害控制或復原
- 受通報機關於接獲通報資通安全事件後，依下列規定時間完成該資通安全事件等級之審核，並得依審核結果變更其等級：
  - 第1級及第2級事件應於接獲後**8小時**內完成審核，第3級及第4級重大事件應於**2小時**內完成審核
  - 受通報機關應於1小時內將審核結果通知主管機關，並提供審核依據之相關資訊
- 主管機關接獲前項之通知後，應依相關資訊，就資通安全事件之等級進行覆核，並得依覆核結果變更其等級。但主管機關認有必要，或前項之機關未依規定通知審核結果時，得就該資通安全事件逕為審核，並得為等級之變更。





## 9-4 資通安全事件通報及應變作業流程(3/5)

### ■ 通報及應變作業流程(2/2)

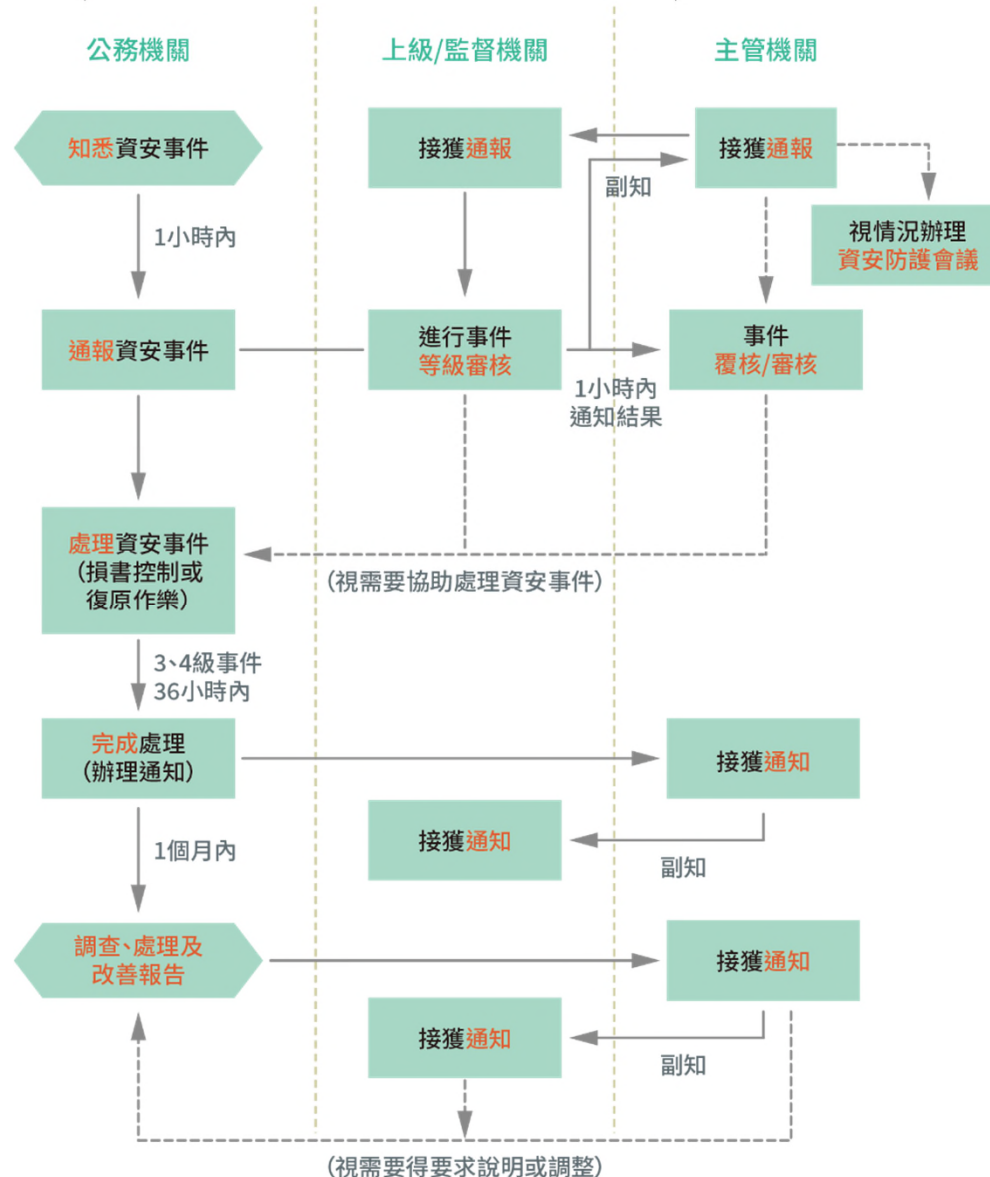


- ※ 通報機關於事件調查過程中，發現事件影響範圍擴大，應適時提出等級變更申請，並說明等級變更原因與事件調查情況，以利審核機關/主管機關儘早知悉，以適時提供必要支援
- ※ 資通安全事件調查、處理及改善報告應於1個月內提交，視情況可提出延後提交申請



## 9-4 資通安全事件通報及應變作業流程(4/5)

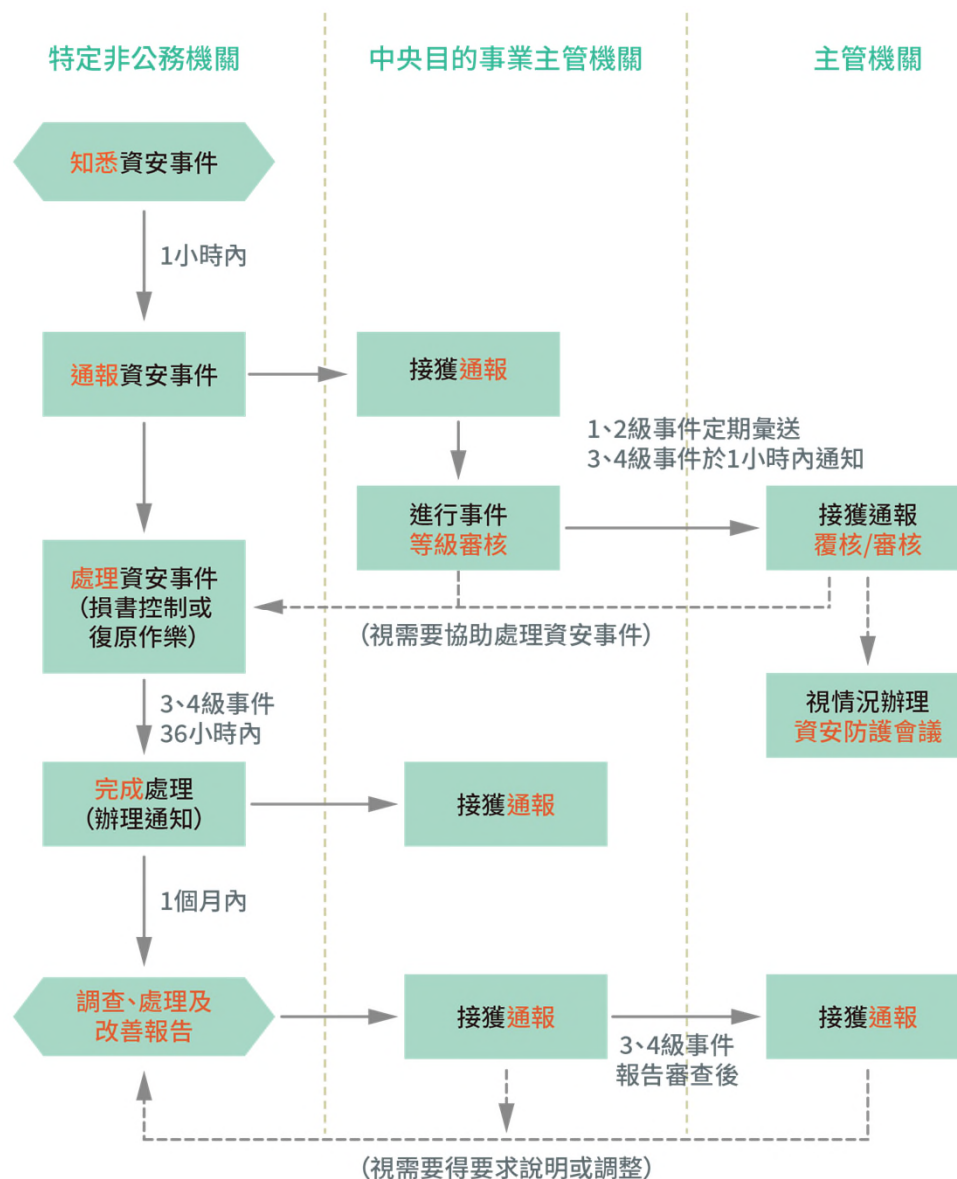
### ■ 公務機關通報及應變作業流程





## 9-4 資通安全事件通報及應變作業流程(5/5)

### ■ 特定非公務機關通報及應變作業流程







## 9-5 資通安全事件通報應變及演練作業

### ■ 通報及應變演練作業

- 總統府、國家安全會議與五院之直屬機關對其自身、所屬或所監督之公務機關，應規劃及辦理資通安全演練作業，並於完成後
- 一個月內，將執行情形及成果報告送交主管機關，演練作業之內容應至少包括下列項目：
  - － 每半年辦理1次社交工程演練
  - － 每年辦理1次資通安全事件通報及應變演練
- 公務機關與特定非公務機關應配合(受通報機關/中央目的事業主管機關)規劃或辦理之資通安全演練作業，其內容得包括下列項目：

| 演練項目          | 公務機關 | 特定<br>非公務機關 |
|---------------|------|-------------|
| 社交工程演練        | √    |             |
| 資通安全事件通報及應變演練 | √    |             |
| 網路攻防演練        | √    | √           |
| 情境演練          | √    | √           |
| 其他必要之演練       | √    | √           |



## 9-6 資通安全事件處理(1/12)

### ■ 資安事件-處理目的

- 確認資安事件是否發生
- 降低對業務與網路服務的中斷時間
- 提供精準與及時的資訊
- 於規定時間內完成損害控制或復原作業
- 保障由政策與法律要求的權利
- 實作控制措施以維護監管鏈
- 讓法務單位可對惡意者提起訴訟



## 9-6 資通安全事件處理(2/12)

### ■ 資安事件-處理計畫

#### ➤ 定期重新審查計畫文件

- 更新人員、科技及業務處理流程

#### ➤ 訓練

- 組織分工與權責、資通安全技能、危機處理、數位鑑識與調查技能及溝通能力

#### ➤ 財務支持

- 預算、額外的設備、專業人員、員工薪資及訓練費用

#### ➤ 演練

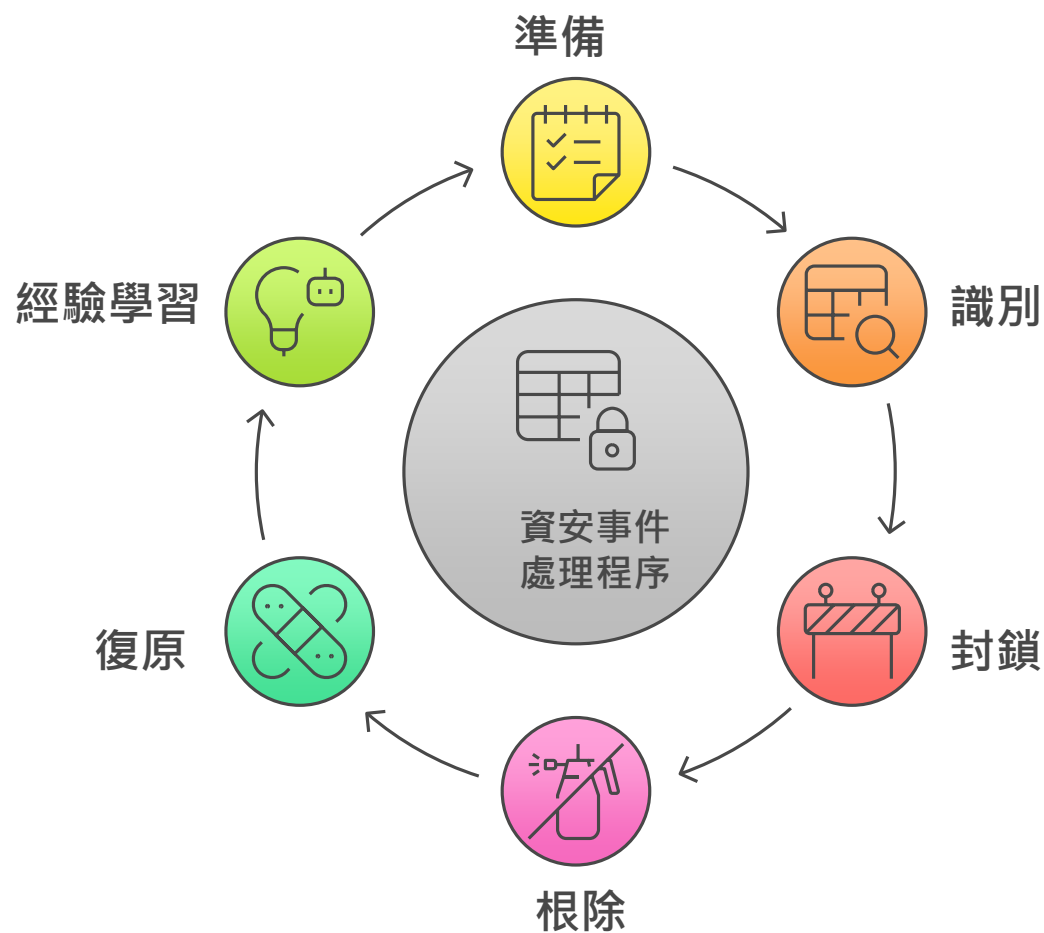
- 定期驗證與修正作業流程



## 9-6 資通安全事件處理(3/12)

### ■ 資安事件-處理程序

- 準備
- 識別
- 封鎖
- 根除
- 復原
- 經驗學習





## 9-6 資通安全事件處理(4/12)

### ■ 資安事件-處理程序-準備(1/2)

- 資安事件成功處理的關鍵是事前的「準備」
  - 組織資安事件處理小組
  - 建立資安事件處理策略
  - 設計資安事件處理程序
  - 建立溝通管道與方式
  - 蒐集所需資源
  - 練習、練習及再練習





## 9-6 資通安全事件處理(5/12)

### ■ 資安事件-處理程序-準備(2/2)

#### ➤ 資安事件處理小組

- 技術部門(IT、資通安全及系統管理者)
- 管理人員
- 法務部門
- 數位鑑識專家
- 公共關係部門
- 人力資源部門
- 實體安全與維護部門
- 通訊部門





## 9-6 資通安全事件處理(6/12)

### ■ 資安事件-處理程序-識別(1/2)

#### ➤ 資安事件無法完全防制，但必須被偵測

- 識別意圖(故意或無意)
- 確認範圍
  - 識別哪些系統、人員及資訊資產被包含在處理的資安事件中
- 保留證據
  - 保護資安事件的事實
- 可疑的事件
  - 新增帳號、新建檔案及檔案的修改
  - 入侵偵測系統觸發的事件與防火牆存取紀錄
  - 效能變差、服務無回應及系統不穩定
- 監聽正在進行的攻擊行為
  - 透過網路封包的蒐集



## 9-6 資通安全事件處理(7/12)

### ■ 資安事件-處理程序-識別(2/2)

#### ➤ 數位證據的取得

- 採用被接受的磁碟映像複製工具(所有磁區的複製，配合雜湊函數以檢驗被複製出來的資料沒有被竄改)
- 配合錄影機記錄螢幕顯示的內容與採證過程

#### ➤ 識別出來的相關證物從發現到提出至法院必須有完整明確的監管紀錄

- 每一項證據必須由可證明身分的人員所保管
- 當保管人交接時必須被記錄
- 在儲存體中的證物必須被保護，以免被污染或變更





## 9-6 資通安全事件處理(8/12)

### ■ 資安事件-處理程序-封鎖

- 當資安事件已被識別，且相關證物監管鏈已被建立後，接下來就開始「封鎖」入侵來源，以避免災害擴大
  - 識別可信任來源
    - 不只是來源網路地址或設備，也包含使用者
  - 避免驚動入侵者以避免證據被銷毀
  - 開始進行證據分析與數位鑑識
  - 減緩攻擊的封鎖行動
    - 變更通行碼與權限
    - 變更主機名稱與IP位址
    - 將可疑的流量導到不存在的位址
    - 阻擋攻擊來源IP或網段
    - 在類似系統上更新修補程式
    - 關閉服務



## 9-6 資通安全事件處理(9/12)

### ■ 資安事件-處理程序-根除

- 一旦資安事件已被控制，接下來要從系統或網路中完全移除惡意程式
  - 決定採用移除或回存方式
    - 是否可以完全移除乾淨
    - 備份資料中是否就有惡意程式
  - 強化防禦機制
    - 建立額外的偵測與防禦方法
    - 提升稽核紀錄的詳細程度
    - 在其他系統中尋找已發現的惡意程式
    - 更嚴謹控管存取來源



## 9-6 資通安全事件處理(10/12)

### ■ 資安事件-處理程序-復原

- 一旦威脅被根除，接下來應開始將業務與服務回復至正常運作狀態
- 加強監控以偵測攻擊是否再發生
  - 客製化入侵偵測規則
  - 在網路、主機及應用程式中，額外實作更詳細的稽核紀錄



## 9-6 資通安全事件處理(11/12)

### ■ 資安事件-處理程序-經驗學習

#### ➤ 召開經驗學習會議

- 在相關處理人員記憶猶新的情況下
- 讓機關在資安事件中學習防護經驗
- 建議修改相關政策或程序，以利未來安全防護機制實作時可避免重蹈覆轍



## 9-6 資通安全事件處理(12/12)

### ■ 資安事件-處理個資外洩

- 在「識別」與「封鎖」階段
  - 應確定個人資料外洩的範圍
- 在「復原」階段
  - 依「個人資料保護法」要求，應主動通知個資被外洩的對象
  - 提供改善方案以防止個資外洩對象進一步的損害



## 9-7 數位證據及數位鑑識(1/3)

### ■ 數位證據(Digital Evidence)

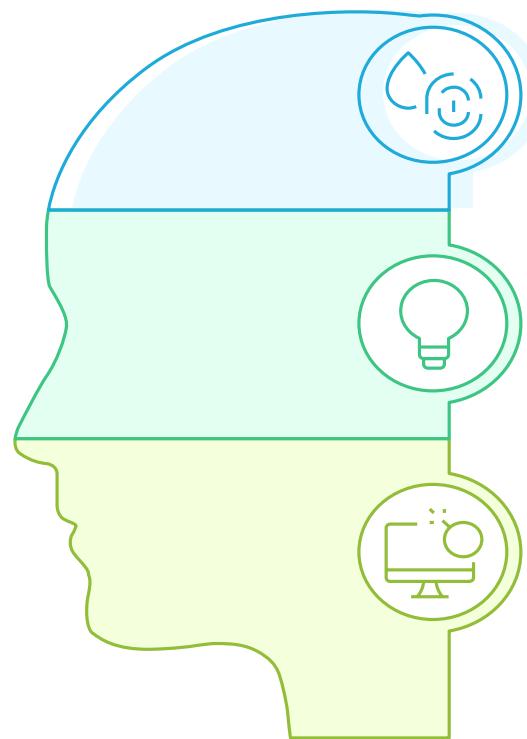
- 由電腦來儲存或是傳送的資料
- 該資料可以用來進行後續的偵查
- 偵查的目的是用來確認或是否定反駁有關於犯罪的推斷  
陳述
- 該資料在法庭上有具體的用途



## 9-7 數位證據及數位鑑識(2/3)

### ■ 數位鑑識(Digital Forensics)

- 數位鑑識是鑑識科學的領域之一
- 探討與電腦犯罪相關證物的處理與調查
- 可運用在法庭上支持或是否定犯罪的推論
- 也可運用在一般場合提供資安事件的調查



#### 資安事件調查

可運用在一般場合  
提供資安事件  
的調查

#### 犯罪的推論

可運用在法庭上  
支持或是否定  
犯罪的推論

#### 探討證物

探討與電腦犯罪  
相關證物的  
處理與調查



## 9-7 數位證據及數位鑑識(3/3)

### ■ 數位鑑識-原則

- 物證的監管鏈(Chain of Custody)
  - 從扣押、蒐集、保管到運送過程，要確保資料的一致性與完整性
- 數位證據的完整性(Evidence Integrity)
  - 必須保持證據的完整性，可利用雜湊函數運算
- 客觀性(Objectivity)
  - 蒐集的資料要是公正且客觀性的法律證據





## 9-8 社交工程(1/7)

### ■ 何謂社交工程？

- 利用人性弱點，應用簡單的溝通與欺騙伎倆，遂行其非法的存取與破壞行為
- 攻擊者不需要具備頂尖的電腦專業技術，只要受害方對於防範詐騙沒有足夠的認知，就可以輕易的避過企業的軟硬體安全防護，騙取到帳號、通行碼、身分證號碼或其他機敏資料
- 利用目前備受矚目的重大事件與新聞做為誘餌，也可能利用日常活動做為誘餌，例如線上理財、投資、帳單管理，以及購物等



## 9-8 社交工程(2/7)

### ■ 社交工程-常見攻擊手法(1/3)

- 社交工程常見的攻擊手法，包括：
  - 網路釣魚(Phishing)
  - 釣魚簡訊(Smishing)
  - 電話詐騙(Vishing)
  - 即時通訊詐騙(Instant Messaging Scams)
  - 冒充(Pretexting)
  - 誘餌(Baiting)
  - 尾隨(Tailgating)
  - 蜜罐陷阱(Honeytrap)



## 9-8 社交工程(3/7)

### ■ 社交工程-常見攻擊手法(2/3)

#### ➤ 網路釣魚(Phishing)

- 攻擊者偽裝成可信賴的實體（如銀行、政府機關、知名企業或公司內部同事），透過電子郵件或其他電子通訊方式發送虛假訊息。

#### ➤ 釣魚簡訊(Smishing)

- Phishing 的簡訊變體（SMS + Phishing）。攻擊者透過手機簡訊發送惡意連結或詐騙訊息。

#### ➤ 電話詐騙(Vishing)

- Phishing 的語音變體（Voice + Phishing）。攻擊者透過電話，冒充特定機構（如銀行客服、電信公司、技術支援人員、執法機關），進行詐騙。。

#### ➤ 即時通訊詐騙(Instant Messaging Scams)

- 攻擊者透過即時通訊軟體（如Line, WhatsApp, Telegram, Facebook Messenger）進行的詐騙



## 9-8 社交工程(4/7)

### ■ 社交工程-常見攻擊手法(3/3)

#### ➤ 冒充(Pretexting)

- 攻擊者事先編造一個虛假但看似合理的故事或情境（Pretext），以獲取目標信任，從而套取資訊或促使對方執行某項操作。

#### ➤ 誘餌(Baiting)

- 攻擊者透過提供具有吸引力的「誘餌」，引誘受害者上鉤，從而達到攻擊目的。

#### ➤ 尾隨 (Tailgating)

- 攻擊者趁受害者進入管制區域時，趁機跟著一起進入

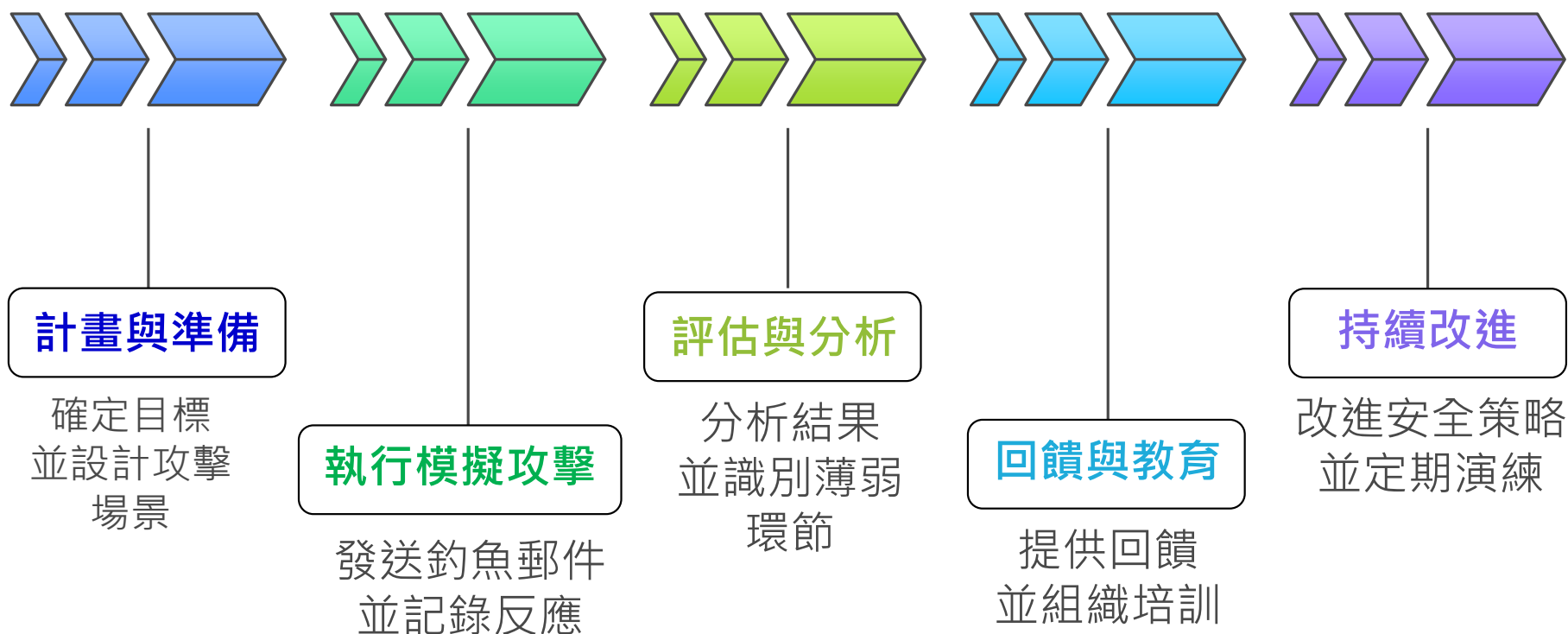
#### ➤ 蜜罐陷阱 (Honeytrap)

- 攻擊者利用浪漫或其他情感關係作為誘惑，誘使目標落入圈套，以獲取敏感資訊或進行勒索。



## 9-8 社交工程(5/7)

### ■ 社交工程演練作業-以電子郵件為例





## 9-8 社交工程(6/7)

### ■ 社交工程-案例

發現近期駭客利用大學系所人員之電子郵件帳號，偽冒監察院名義，寄送含惡意附檔之社交工程電子郵件給政府機關人員，企圖誘騙收件人開啟惡意附檔以植入後門程式，並竊取電腦機敏資訊，相關情資已提供各機關聯防監控防護建議。





## 9-8 社交工程(7/7)

### ■ 社交工程-正確防範觀念

- 隨時提高警覺，在沒有適當的認證情況下，不應輕信他人，只要出現社交工程攻擊警訊，都應保持小心求證的戒心
  - 不未經確認即提供資料
  - 不開啟來路不明的電子郵件及附加檔案
  - 不連結及登入未經確認的網站
  - 不下載非法軟體及檔案
  - 避免在公共場所使用免費WiFi熱點
- 任何資訊釋出時都要確認要求者的身分及對方經過授權
- 遇到疑似攻擊事件時應向有關單位通報



## 第9單元-分組討論

### ■ 分享資通安全事件處理經驗

1. 機關遭遇過哪些資通安全事件
2. 機關是否有無法處理之資通安全事件
3. 機關辦理哪些演練及處理資通安全事件作法
4. 機關採集數位證據與數位鑑識作法

### ■ 分享機關遭受社交工程攻擊經驗

1. 機關遭受過哪些類型的社交工程攻擊
2. 機關遭到入侵成功案例及後續處理作法
3. 機關如何防範社交工程攻擊